BỘ GIÁO DỤC VÀ ĐÀO TẠO

TRƯỜNG ĐẠI HỌC CÔNG NGHỆ TP. HCM

ĐỒ ÁN MÔN HỌC

LẬP TRÌNH AN NINH THÔNG TIN

XÂY DỰNG HỆ THỐNG QUẢN LÝ VÀ KIỂM TRA CHỨNG THƯ SỐ SSL/TLS CHO MÁY CHỦ WEB

Giảng viên hướng dẫn: ThS. Nguyễn Trọng Minh Hồng Phước

Sinh viên thực hiện	Lớp	MSSV
1. Trần Tăng Trường Thịnh	23DATA1	2387701939
2. Hà Tuấn Anh	23DATA1	2387700002
3. Trịnh Thành Đông	23DATA1	2387700372
4. Hoàng Xuân Đạt	23DATA1	2387700013

TP. Hồ Chí Minh, 2026

BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC CÔNG NGHỆ TP. HCM

ĐỒ ÁN MÔN HỌC

LẬP TRÌNH AN NINH THÔNG TIN

XÂY DỰNG HỆ THỐNG QUẢN LÝ VÀ KIỂM TRA CHỨNG THƯ SỐ SSL/TLS CHO MÁY CHỦ WEB

Giảng viên hướng dẫn: ThS. Nguyễn Trọng Minh Hồng Phước

Sinh viên thực hiện	Lớp	MSSV
1. Trần Tăng Trường Thịnh	23DATA1	2387701939
2. Hà Tuấn Anh	23DATA1	2387700002
3. Trịnh Thành Đông	23DATA1	2387700372
4. Hoàng Xuân Đạt	23DATA1	2387700013

TP. Hồ Chí Minh, 2026

LỜI MỞ ĐẦU

Ngày nay, hầu hết các dịch vụ trên Internet như ngân hàng trực tuyến, thương mại điện tử, cổng thông tin hay hệ thống nội bộ của doanh nghiệp đều vận hành trên giao thức HTTPS. Nền tảng của HTTPS là giao thức TLS (trước đây là SSL) và chứng thư số X.509 – thứ đóng vai trò như "căn cước" của máy chủ, giúp trình duyệt xác minh rằng mình đang kết nối đúng với máy chủ thật và mọi dữ liệu trao đổi đều được mã hóa.

Tuy nhiên, chứng thư số có thời hạn, có chuỗi tin cậy phức tạp và phải được cấu hình đúng trên từng máy chủ. Chỉ cần một chứng thư hết hạn, cấp sai tên miền, thiếu chứng thư trung gian, hay máy chủ còn bật các phiên bản giao thức cũ là người dùng sẽ gặp cảnh báo bảo mật, dịch vụ bị gián đoạn, thậm chí tạo điều kiện cho kẻ tấn công nghe lén hoặc giả mạo. Khi số lượng máy chủ tăng lên, việc theo dõi thủ công trở nên không khả thi và dễ bỏ sót.

Xuất phát từ thực tế đó, nhóm em thực hiện đề tài **"Xây dựng hệ thống quản lý và kiểm tra chứng thư số SSL/TLS cho máy chủ Web"** với sản phẩm là hệ thống **CertGuard**. Hệ thống cho phép quản lý tập trung danh mục máy chủ, tự động kết nối TLS tới từng máy chủ để kiểm tra chứng thư và cấu hình, chấm điểm mức độ an toàn, theo dõi lịch sử, giám sát định kỳ và gửi cảnh báo qua email. Đồng thời, vì đây là đồ án môn Lập trình an ninh thông tin, bản thân hệ thống cũng được xây dựng theo hướng an toàn: chống SSRF, chống dò mật khẩu, chống CSRF, ghi nhật ký kiểm toán và bảo vệ thông tin bí mật.

Báo cáo trình bày cơ sở lý thuyết về mật mã khóa công khai, chứng thư số, hạ tầng khóa công khai và giao thức TLS; quá trình phân tích, thiết kế, cài đặt hệ thống; và kết quả thực nghiệm trên môi trường gồm bảy web server Nginx thật được cấu hình với các loại chứng thư khác nhau.

LỜI CẢM ƠN

Lời đầu tiên, nhóm em xin gửi lời cảm ơn chân thành đến thầy **ThS. Nguyễn Trọng Minh Hồng Phước** – giảng viên phụ trách môn Lập trình an ninh thông tin – đã tận tình giảng dạy, định hướng và góp ý cho nhóm trong suốt quá trình thực hiện đồ án. Những kiến thức và nhận xét của thầy, đặc biệt là yêu cầu sản phẩm phải được kiểm chứng trên môi trường thực tế, đã giúp nhóm hoàn thiện đề tài theo hướng thiết thực hơn.

Nhóm em cũng xin cảm ơn Khoa Công nghệ Thông tin, Trường Đại học Công nghệ TP. Hồ Chí Minh đã tạo điều kiện học tập và nghiên cứu để nhóm có cơ hội vận dụng kiến thức vào một sản phẩm cụ thể.

Do thời gian và kinh nghiệm còn hạn chế, báo cáo không tránh khỏi những thiếu sót. Nhóm em rất mong nhận được sự góp ý của thầy để đề tài được hoàn thiện hơn.

Nhóm em xin chân thành cảm ơn!

TP. Hồ Chí Minh, tháng 11 năm 2026

Nhóm sinh viên thực hiện

Trần Tăng Trường Thịnh

Hà Tuấn Anh

Trịnh Thành Đông

Hoàng Xuân Đạt

NHIỆM VỤ ĐỒ ÁN

Xây dựng hệ thống quản lý và kiểm tra chứng thư số SSL/TLS cho máy chủ Web (CertGuard) với các nhiệm vụ cụ thể:

- Tìm hiểu cơ sở lý thuyết về mật mã khóa công khai, chữ ký số, chứng thư số X.509, hạ tầng khóa công khai (PKI), giao thức SSL/TLS, cơ chế thu hồi chứng thư (CRL, OCSP) và các lỗi cấu hình thường gặp.
- Xây dựng module kiểm tra: bắt tay TLS thật với máy chủ, phân tích chứng thư, xác thực chuỗi tin cậy, kiểm tra thời hạn, tên miền, độ mạnh khóa, thuật toán ký, phiên bản giao thức, bộ mã hóa, HSTS và trạng thái thu hồi.
- Xây dựng chức năng quản lý: danh mục máy chủ, lịch sử quét, phát hiện chứng thư bị thay đổi, quản lý Root CA tin cậy, chấm điểm và phân loại trạng thái.
- Xây dựng chức năng giám sát định kỳ và cảnh báo qua email khi chứng thư sắp hết hạn hoặc có lỗi nghiêm trọng.
- Bảo đảm an toàn cho chính hệ thống: xác thực, băm mật khẩu, khóa tài khoản, CSRF, phân quyền, chống SSRF, nhật ký kiểm toán.
- Dựng môi trường thực nghiệm gồm các web server Nginx thật, kiểm thử và đối chứng kết quả với công cụ độc lập (OpenSSL, trình duyệt).

NHẬN XÉT CỦA GIẢNG VIÊN

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

MỤC LỤC

LỜI MỞ ĐẦU ..... **i**
LỜI CẢM ƠN ..... **ii**
NHIỆM VỤ ĐỒ ÁN ..... **iii**
NHẬN XÉT CỦA GIẢNG VIÊN ..... **iv**
MỤC LỤC ..... **v**
DANH MỤC HÌNH ẢNH ..... **vii**
DANH MỤC BẢNG BIỂU ..... **ix**
DANH MỤC TỪ VIẾT TẮT ..... **x**
CHƯƠNG 1: TỔNG QUAN **1**
1.1. Đặt vấn đề 1
1.2. Mục tiêu đề tài 1
1.3. Đối tượng và phạm vi 2
1.4. Phương pháp thực hiện 2
1.5. Cấu trúc báo cáo 2
CHƯƠNG 2: CƠ SỞ LÝ THUYẾT **4**
2.1. Mật mã khóa công khai và chữ ký số 4
2.1.1. Mật mã khóa công khai 4
2.1.2. Hàm băm 4
2.1.3. Chữ ký số 4
2.2. Chứng thư số X.509 4
2.3. Hạ tầng khóa công khai và chuỗi tin cậy 5
2.4. Giao thức SSL/TLS 6
2.4.1. Lịch sử và vị trí của TLS 6
2.4.2. Quá trình bắt tay TLS 7
2.4.3. Bộ mã hóa, bảo mật chuyển tiếp và HSTS 7
2.5. Thu hồi chứng thư: CRL và OCSP 8
2.6. Các lỗi chứng thư và cấu hình thường gặp 8
2.7. Các lỗ hổng ứng dụng web liên quan đến hệ thống 9
2.8. Công nghệ sử dụng 9
CHƯƠNG 3: PHÂN TÍCH VÀ THIẾT KẾ HỆ THỐNG **11**
3.1. Phân tích yêu cầu 11
3.1.1. Tác nhân và chức năng 11

3.1.2. Yêu cầu phi chức năng 12
3.2. Kiến trúc tổng thể 13
3.3. Luồng xử lý kiểm tra chứng thư 14
3.4. Quy tắc đánh giá và chấm điểm 16
3.5. Giám sát định kỳ và cảnh báo 17
3.6. Thiết kế cơ sở dữ liệu 18
3.7. Thiết kế bảo mật cho hệ thống 19
CHƯƠNG 4: CÀI ĐẶT VÀ KẾT QUẢ THỰC NGHIỆM 20
4.1. Môi trường thực nghiệm 20
4.2. Xây dựng các web server kiểm thử 21
4.3. Cài đặt các module chính 22
4.3.1. Chống SSRF khi phân giải tên miền 22
4.3.2. Bắt tay TLS và lấy chuỗi chứng thư 22
4.3.3. Phân loại lỗi chuỗi tin cậy 22
4.3.4. Xác thực, khóa tài khoản và CSRF 23
4.4. Giao diện và kết quả kiểm tra 23
4.4.1. Đăng nhập và trạng thái ban đầu 23
4.4.2. Khai báo Root CA nội bộ 24
4.4.3. Máy chủ cấu hình chuẩn 25
4.4.4. Các máy chủ có lỗi 26
4.4.5. Trang tổng quan giám sát 28
4.4.6. Lịch sử quét, kiểm tra nhanh và phân tích file 29
4.5. Cảnh báo qua email 31
4.6. Kiểm thử bảo mật hệ thống 32
4.6.1. Chống SSRF 32
4.6.2. Chống dò mật khẩu 33
4.6.3. Nhật ký kiểm toán và các kiểm thử khác 35
4.7. Đối chứng kết quả và đánh giá 36
CHƯƠNG 5: KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN 38
5.1. Kết quả đạt được 38
5.2. Hạn chế 38
5.3. Hướng phát triển 39
TÀI LIỆU THAM KHẢO 40

DANH MỤC HÌNH ẢNH

Hình 1. Chuỗi tin cậy Root CA – CA trung gian – chứng thư máy chủ 6
Hình 2. Sơ đồ tác nhân và chức năng (use case) của hệ thống.....11
Hình 3. Kiến trúc tổng thể của hệ thống CertGuard.....13
Hình 4. Luồng xử lý một lần kiểm tra chứng thư.....15
Hình 5. Sơ đồ cơ sở dữ liệu của hệ thống.....18
Hình 6. Mô hình môi trường thực nghiệm trên một máy tính.....20
Hình 7. Bảy web server Nginx đang chạy trong Docker Desktop 21
Hình 8. Hàm phân giải tên miền có kiểm tra SSRF (scanner.py) 22
Hình 9. Bắt tay TLS và thăm dò phiên bản giao thức (scanner.py) 22
Hình 10. Phân loại lỗi chuỗi tin cậy (scanner.py) 23
Hình 11. Khóa tài khoản và kiểm tra CSRF token (security.py).....23
Hình 12. Giao diện đăng nhập.....24
Hình 13. Trang tổng quan khi cơ sở dữ liệu còn trống 24
Hình 14. Trang cài đặt: Root CA tin cậy, kênh cảnh báo và gửi thử email 25
Hình 15. Kết quả kiểm tra máy chủ chuẩn đạt điểm A+.....26
Hình 16. Chuỗi chứng thư của máy chủ chuẩn 26
Hình 17. Máy chủ expiring: chứng thư chỉ còn 5 ngày hiệu lực.....26
Hình 18. Máy chủ expired: chứng thư đã hết hạn, điểm F 27
Hình 19. Máy chủ selfsigned: chứng thư tự ký, chuỗi chỉ có một chứng thư.....27
Hình 20. Máy chủ wronghost: chứng thư cấp cho tên miền khác.....27
Hình 21. Máy chủ incomplete: máy chủ chỉ gửi một chứng thư, thiếu CA trung gian.28
Hình 22. Máy chủ weak: khóa RSA 1024 bit, còn bật TLS 1.0/1.1, chấp nhận cipher yếu, không HSTS.....28
Hình 23. Trang tổng quan sau khi giám sát bảy máy chủ 29
Hình 24. Lịch sử quét và cảnh báo của một máy chủ.....30
Hình 25. Kiểm tra nhanh một URL.....30
Hình 26. Phân tích file chứng thư tải lên.....31
Hình 27. Các email cảnh báo nhận được trong Gmail 32
Hình 28. Nội dung email cảnh báo chứng thư hết hạn.....32
Hình 29. Chặn truy cập địa chỉ metadata 169.254.169.254 33
Hình 30. Chặn truy cập địa chỉ nội bộ 127.0.0.1.....33
Hình 31. Tài khoản bị khóa sau 5 lần nhập sai mật khẩu.....33

Hình 32. Nhập đúng mật khẩu trong thời gian bị khóa vẫn bị từ chối.....34
Hình 33. Trang quản lý người dùng 34
Hình 34. Nhật ký kiểm toán ghi lại các sự kiện bảo mật.....35
Hình 35. Lệnh đối chứng OpenSSL được cung cấp trên trang kết quả.....36
Hình 36. Kết quả đối chứng bằng OpenSSL 36

DANH MỤC BẢNG BIỂU

Bảng 1. Các trường quan trọng của chứng thư X.509 v3 5
Bảng 2. Các phiên bản SSL/TLS 6
Bảng 3. Các lỗi chứng thư và cấu hình TLS thường gặp 8
Bảng 4. Các công nghệ sử dụng trong đề tài 9
Bảng 5. Danh sách chức năng của hệ thống 12
Bảng 6. Các thành phần của hệ thống 13
Bảng 7. Quy tắc chấm điểm của CertGuard 16
Bảng 8. Mô tả các bảng trong cơ sở dữ liệu 18
Bảng 9. Các mối đe dọa và biện pháp bảo vệ hệ thống 19
Bảng 10. Môi trường cài đặt và thực nghiệm 20
Bảng 11. Bảy web server kiểm thử và kết quả mong đợi 21
Bảng 12. Kết quả kiểm thử bảo mật 35
Bảng 13. Đối chứng kết quả CertGuard với OpenSSL và Chrome 36

DANH MỤC TỪ VIẾT TẮT

STT	Từ viết tắt	Tiếng Anh	Tiếng Việt
1	CA	Certificate Authority	Tổ chức cấp chứng thư số
2	CRL	Certificate Revocation List	Danh sách chứng thư bị thu hồi
3	CSR	Certificate Signing Request	Yêu cầu ký chứng thư
4	CSRF	Cross-Site Request Forgery	Giả mạo yêu cầu liên trang
5	DNS	Domain Name System	Hệ thống phân giải tên miền
6	ECDHE	Elliptic Curve Diffie–Hellman Ephemeral	Trao đổi khóa Diffie–Hellman tạm thời trên đường cong elliptic
7	HSTS	HTTP Strict Transport Security	Cơ chế bắt buộc truy cập qua HTTPS
8	HTTPS	Hypertext Transfer Protocol Secure	Giao thức HTTP bảo mật qua TLS
9	OCSP	Online Certificate Status Protocol	Giao thức kiểm tra trạng thái chứng thư trực tuyến
10	PFS	Perfect Forward Secrecy	Bảo mật chuyển tiếp
11	PKI	Public Key Infrastructure	Hạ tầng khóa công khai
12	RSA	Rivest–Shamir–Adleman	Thuật toán mật mã khóa công khai RSA
13	SAN	Subject Alternative Name	Tên thay thế của chủ thể (danh sách tên miền)
14	SHA	Secure Hash Algorithm	Họ hàm băm an toàn
15	SMTP	Simple Mail Transfer Protocol	Giao thức gửi thư điện tử
16	SNI	Server Name Indication	Chỉ định tên máy chủ trong bắt tay TLS
17	SSL	Secure Sockets Layer	Tầng socket bảo mật (tiền thân của TLS)
18	SSRF	Server-Side Request Forgery	Giả mạo yêu cầu phía máy chủ
19	TLS	Transport Layer Security	Bảo mật tầng vận chuyển
20	XSS	Cross-Site Scripting	Tấn công chèn mã kịch bản liên trang

CHƯƠNG 1: TỔNG QUAN

1.1. Đặt vấn đề

Chứng thư số SSL/TLS là thành phần bắt buộc của mọi website và dịch vụ web hiện đại. Trình duyệt chỉ hiển thị biểu tượng ổ khóa và cho phép người dùng tiếp tục khi chứng thư của máy chủ còn hiệu lực, được cấp cho đúng tên miền và lần ngược được tới một tổ chức cấp chứng thư (CA) đáng tin cậy. Nếu một trong các điều kiện đó không thỏa mãn, người dùng sẽ thấy trang cảnh báo đỏ "Kết nối của bạn không phải là kết nối riêng tư", còn các ứng dụng gọi API sẽ từ chối kết nối.

Trên thực tế, sự cố do chứng thư gây ra rất phổ biến và thường xuất phát từ những nguyên nhân đơn giản: quên gia hạn, cài chứng thư nhưng thiếu chứng thư trung gian, cấp nhầm tên miền, hoặc máy chủ cũ vẫn bật TLS 1.0/1.1 và các bộ mã hóa yếu. Một ví dụ được nhắc đến nhiều là sự cố ngày 03/02/2020, khi dịch vụ Microsoft Teams bị gián đoạn trong nhiều giờ vì một chứng thư xác thực hết hạn. Bên cạnh đó, thời hạn tối đa của chứng thư công cộng đang được rút ngắn dần theo quyết định của CA/Browser Forum, nghĩa là các tổ chức sẽ phải gia hạn thường xuyên hơn và nguy cơ bỏ sót càng lớn.

Với một tổ chức có hàng chục đến hàng trăm máy chủ, việc kiểm tra thủ công từng máy chủ bằng trình duyệt hay dòng lệnh là tốn thời gian và không bền vững. Vì vậy cần một hệ thống **quản lý tập trung**, **tự động kiểm tra** và **cảnh báo sớm**, đồng thời bản thân hệ thống đó phải được bảo vệ tốt, vì nó có quyền kết nối tới nhiều máy chủ trong tổ chức.

1.2. Mục tiêu đề tài

Mục tiêu của đề tài là xây dựng hệ thống CertGuard có khả năng:

- **Quản lý** danh mục máy chủ Web cần theo dõi cùng thông tin chứng thư, lịch sử các lần kiểm tra và các Root CA nội bộ được tin cậy.
- **Kiểm tra** chứng thư và cấu hình TLS bằng cách bắt tay TLS thật với máy chủ, phát hiện các lỗi phổ biến và chấm điểm từ A+ đến F.
- **Giám sát** định kỳ toàn bộ danh mục, phát hiện chứng thư sắp hết hạn hoặc bị thay đổi, và **cảnh báo** qua email.

- **Tự bảo vệ** trước các tấn công phổ biến đối với ứng dụng web và công cụ quét, phù hợp với yêu cầu của môn Lập trình an ninh thông tin.
- Cho kết quả **kiểm chứng được**: mọi dữ liệu đều do hệ thống thu thập từ máy chủ thật và có thể đối chứng bằng OpenSSL hoặc trình duyệt.

1.3. Đối tượng và phạm vi

- **Đối tượng sử dụng:** quản trị viên hệ thống, bộ phận vận hành và an ninh thông tin của tổ chức có nhiều máy chủ Web.
- **Đối tượng được kiểm tra:** chứng thư X.509 và cấu hình TLS của các máy chủ HTTPS, bao gồm máy chủ nội bộ (dùng CA nội bộ) và website công khai (dùng CA công cộng).
- **Phạm vi:** hệ thống hoạt động theo mô hình web tập trung, không cài tác tử (agentless) trên máy chủ đích. Việc cấp phát, gia hạn và thu hồi chứng thư do CA bên ngoài đảm nhận và được đề xuất trong hướng phát triển.
- **Môi trường thực nghiệm:** một máy tính chạy CertGuard và bảy web server Nginx trong Docker, mỗi máy chủ được cấu hình một tình huống chứng thư khác nhau.

1.4. Phương pháp thực hiện

- Nghiên cứu tài liệu: các tiêu chuẩn RFC 5280 (X.509), RFC 8446 (TLS 1.3), RFC 6960 (OCSP), RFC 6797 (HSTS), RFC 8996, khuyến nghị cấu hình TLS của Mozilla và tài liệu OWASP.
- Phân tích – thiết kế hệ thống theo hướng mô-đun: lõi kiểm tra tách biệt khỏi giao diện, giám sát và lưu trữ.
- Lập trình bằng Python với thư viện `cryptography`, `ssl` và framework Flask.
- Dựng môi trường kiểm thử thật bằng Docker và Nginx; đối chứng kết quả với OpenSSL và trình duyệt Chrome.

1.5. Cấu trúc báo cáo

Ngoài phần mở đầu và kết luận, báo cáo gồm các chương:

- **Chương 1 – Tổng quan:** đặt vấn đề, mục tiêu, phạm vi và phương pháp.

- **Chương 2 – Cơ sở lý thuyết:** mật mã khóa công khai, chứng thư số X.509, PKI và chuỗi tin cậy, giao thức SSL/TLS, thu hồi chứng thư, các lỗi cấu hình và các lỗ hổng liên quan.
- **Chương 3 – Phân tích và thiết kế hệ thống:** yêu cầu, kiến trúc, luồng xử lý, quy tắc chấm điểm, cơ sở dữ liệu và thiết kế bảo mật.
- **Chương 4 – Cài đặt và kết quả thực nghiệm:** môi trường, cài đặt các module chính, giao diện và kết quả kiểm thử.
- **Chương 5 – Kết luận và hướng phát triển.**

CHƯƠNG 2: CƠ SỞ LÝ THUYẾT

2.1. Mật mã khóa công khai và chữ ký số

2.1.1. Mật mã khóa công khai

Mật mã khóa công khai (mật mã bất đối xứng) sử dụng một cặp khóa có quan hệ toán học với nhau: **khóa công khai** (public key) được công bố rộng rãi và **khóa riêng** (private key) được giữ bí mật tuyệt đối. Dữ liệu được mã hóa bằng khóa công khai chỉ giải mã được bằng khóa riêng tương ứng; ngược lại, thao tác ký bằng khóa riêng có thể được bất kỳ ai kiểm tra bằng khóa công khai. Hai họ thuật toán phổ biến trong TLS là **RSA** (độ an toàn dựa trên bài toán phân tích số nguyên lớn) và **ECDSA** (dựa trên bài toán logarit rời rạc trên đường cong elliptic).

Độ dài khóa quyết định mức độ an toàn. Hiện nay khóa RSA tối thiểu được chấp nhận là 2048 bit; khóa 1024 bit được xem là không an toàn. Với ECDSA, đường cong P-256 (256 bit) cho mức an toàn tương đương RSA 3072 bit.

2.1.2. Hàm băm

Hàm băm mật mã biến một thông điệp có độ dài bất kỳ thành một giá trị băm có độ dài cố định, có tính một chiều và kháng va chạm. Trong chứng thư số, hàm băm được dùng khi ký và để tạo **dấu vân tay (fingerprint)** của chứng thư. Các hàm MD5 và SHA-1 đã bị phá về tính kháng va chạm nên không còn được dùng để ký chứng thư; SHA-256 là lựa chọn phổ biến hiện nay.

2.1.3. Chữ ký số

Chữ ký số được tạo bằng cách băm dữ liệu rồi ký giá trị băm bằng khóa riêng. Bên nhận băm lại dữ liệu, dùng khóa công khai để xác minh chữ ký; nếu khớp thì dữ liệu chắc chắn đến từ người giữ khóa riêng và không bị sửa đổi. Toàn bộ cơ chế tin cậy của chứng thư số dựa trên chữ ký số: mỗi chứng thư mang chữ ký của CA đã cấp nó.

2.2. Chứng thư số X.509

Chứng thư số là một văn bản điện tử gắn **danh tính** (ví dụ tên miền của máy chủ) với một **khóa công khai**, được CA ký xác nhận. Định dạng chuẩn là X.509 phiên bản 3, được đặc tả trong RFC 5280. Có thể hình dung chứng thư như căn cước của website: tên chủ thể tương ứng họ tên, khóa công khai tương ứng ảnh chân dung, thời

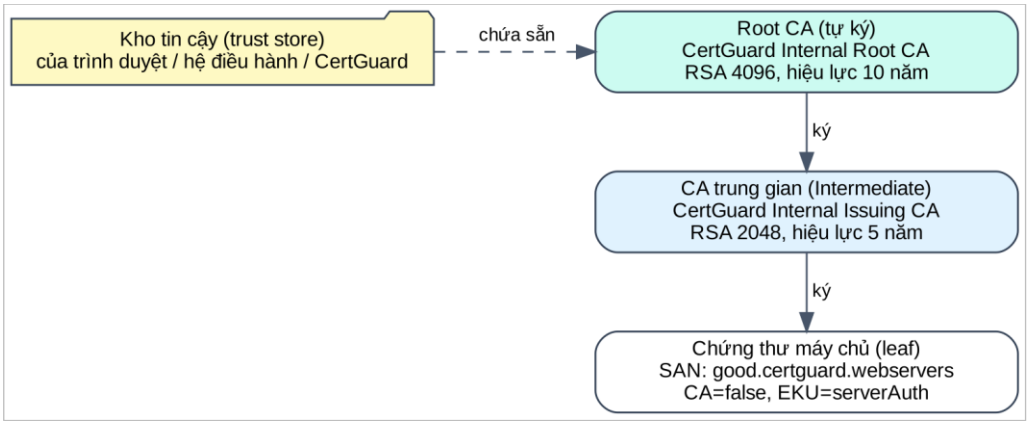
hạn hiệu lực tương ứng ngày hết hạn, và chữ ký của CA tương ứng con dấu của cơ quan cấp. Các trường quan trọng được trình bày trong bảng sau.

Bảng 1. Các trường quan trọng của chứng thư X.509 v3

Trường / phần mở rộng	Ý nghĩa	CertGuard kiểm tra
Subject / Issuer	Chủ thể được cấp và tổ chức đã cấp chứng thư	Hiển thị; dùng để dựng chuỗi tin cậy
Validity (notBefore, notAfter)	Khoảng thời gian chứng thư có hiệu lực	Hết hạn, chưa hiệu lực, số ngày còn lại
Subject Public Key Info	Khóa công khai và thuật toán (RSA, ECDSA…)	Độ dài khóa tối thiểu
Signature Algorithm	Thuật toán băm và ký của CA	Phát hiện MD5, SHA-1
Subject Alternative Name (SAN)	Danh sách tên miền/IP mà chứng thư áp dụng	Khớp tên miền, hỗ trợ ký tự đại diện *.
Basic Constraints	Chứng thư có phải CA hay không	Phân biệt chứng thư máy chủ và CA
Key Usage / Extended Key Usage	Mục đích sử dụng khóa (vd: serverAuth)	Do bộ xác thực X.509 kiểm tra
Authority Information Access	Địa chỉ OCSP và địa chỉ tải chứng thư CA	Truy vấn OCSP
CRL Distribution Points	Địa chỉ tải danh sách thu hồi	Tải và kiểm tra CRL

2.3. Hạ tầng khóa công khai và chuỗi tin cậy

Hạ tầng khóa công khai (PKI) là tập hợp các tổ chức, chính sách và kỹ thuật để cấp phát, quản lý và thu hồi chứng thư. Trình duyệt không thể biết trước mọi chứng thư, nên nó tin vào một số ít **Root CA** được cài sẵn trong **kho tin cậy** (trust store) của hệ điều hành hoặc trình duyệt. Root CA thường không ký trực tiếp cho máy chủ mà ký cho **CA trung gian**; CA trung gian mới ký cho chứng thư của máy chủ. Khi bắt tay TLS, máy chủ gửi chứng thư của mình kèm các chứng thư trung gian; trình duyệt kiểm tra chữ ký từng mắt xích đi lên cho tới một Root CA có trong kho tin cậy.



Hình 1. Chuỗi tin cậy Root CA – CA trung gian – chứng thư máy chủ

Một số khái niệm liên quan:

– **Chứng thư tự ký (self-signed):** được ký bằng chính khóa riêng của nó. Root CA là chứng thư tự ký hợp lệ vì đã được đưa vào kho tin cậy sau quá trình kiểm định; còn chứng thư máy chủ tự ký thì không thể tin cậy, vì bất kỳ ai cũng có thể tự tạo một chứng thư mang tên miền của người khác.

– **CA công cộng và CA nội bộ:** CA công cộng (Let's Encrypt, DigiCert…) được mọi trình duyệt tin cậy và chỉ cấp cho tên miền công khai; CA nội bộ do tổ chức tự vận hành để cấp chứng thư cho máy chủ nội bộ, và chỉ được tin cậy trên các máy đã cài Root CA nội bộ.

– **Chuỗi không đầy đủ:** máy chủ quên gửi chứng thư trung gian. Một số trình duyệt có thể tự tải bù, nhưng nhiều ứng dụng và thư viện khác sẽ báo lỗi.

2.4. Giao thức SSL/TLS

2.4.1. Lịch sử và vị trí của TLS

SSL do Netscape phát triển giữa thập niên 1990, sau đó được IETF chuẩn hóa và đổi tên thành TLS. Dù tên gọi "chứng thư SSL" vẫn phổ biến, mọi kết nối an toàn hiện nay đều dùng TLS. TLS nằm giữa tầng vận chuyển (TCP) và tầng ứng dụng; HTTPS chính là HTTP chạy bên trong một kết nối TLS, mặc định trên cổng 443. TLS cung cấp ba thuộc tính: **bí mật** (mã hóa dữ liệu), **toàn vẹn** (phát hiện sửa đổi) và **xác thực** máy chủ (thông qua chứng thư số).

Bảng 2. Các phiên bản SSL/TLS

Phiên bản	Năm	Đặc tả	Tình trạng hiện nay

Phiên bản	Năm	Đặc tả	Tình trạng hiện nay
SSL 2.0 / SSL 3.0	1995 / 1996	RFC 6101 (lịch sử)	Đã bị phá, cấm sử dụng (RFC 6176, RFC 7568)
TLS 1.0	1999	RFC 2246	Đã loại bỏ theo RFC 8996 (2021)
TLS 1.1	2006	RFC 4346	Đã loại bỏ theo RFC 8996 (2021)
TLS 1.2	2008	RFC 5246	An toàn nếu chỉ dùng bộ mã hóa mạnh
TLS 1.3	2018	RFC 8446	Phiên bản khuyến nghị, an toàn nhất

2.4.2. Quá trình bắt tay TLS

Trước khi trao đổi dữ liệu, máy khách và máy chủ thực hiện quá trình **bắt tay (handshake)**. Với TLS 1.3, quá trình rút gọn như sau:

- **ClientHello:** máy khách gửi các phiên bản và bộ mã hóa hỗ trợ, phần khóa Diffie–Hellman tạm thời và tên máy chủ cần kết nối (phần mở rộng **SNI**).
- **ServerHello:** máy chủ chọn phiên bản, bộ mã hóa và gửi phần khóa Diffie–Hellman của mình; hai bên tính ra khóa phiên chung.
- **Certificate và CertificateVerify:** máy chủ gửi chuỗi chứng thư và chữ ký chứng minh nó giữ khóa riêng tương ứng.
- **Finished:** hai bên xác nhận toàn bộ quá trình bắt tay không bị sửa đổi, sau đó dữ liệu ứng dụng được mã hóa bằng khóa phiên.

Ở bước thứ ba, máy khách (trình duyệt hoặc CertGuard) xác thực chứng thư: kiểm tra thời hạn, tên miền, chữ ký trong chuỗi và điểm neo tin cậy. Đây chính là bước mà CertGuard tái hiện và phân tích chi tiết.

2.4.3. Bộ mã hóa, bảo mật chuyển tiếp và HSTS

Bộ mã hóa (cipher suite) quy định thuật toán trao đổi khóa, xác thực, mã hóa và toàn vẹn. Các bộ mã hóa cũ như RC4, 3DES, NULL hay EXPORT đều không còn an toàn. Ngoài ra, nếu dùng trao đổi khóa RSA tĩnh, khóa phiên được mã hóa trực tiếp bằng khóa công khai của máy chủ; khi khóa riêng của máy chủ bị lộ, kẻ tấn công có thể giải mã lại toàn bộ lưu lượng đã ghi lén trước đó. Các bộ mã hóa dùng (EC)DHE

tạo khóa tạm thời cho từng phiên nên đạt được **bảo mật chuyển tiếp (Forward Secrecy)**.

HSTS (RFC 6797) là header HTTP `Strict-Transport-Security` yêu cầu trình duyệt chỉ truy cập trang qua HTTPS trong một khoảng thời gian, giúp ngăn tấn công hạ cấp xuống HTTP.

2.5. Thu hồi chứng thư: CRL và OCSP

Khi khóa riêng bị lộ hoặc máy chủ ngừng sử dụng, chứng thư cần bị **thu hồi** trước thời hạn. Có hai cơ chế chính:

- **CRL (Certificate Revocation List):** danh sách số serial các chứng thư đã bị thu hồi, được CA ký và công bố định kỳ tại địa chỉ ghi trong phần mở rộng CRL Distribution Points.
- **OCSP (Online Certificate Status Protocol, RFC 6960):** máy khách gửi truy vấn tới máy chủ OCSP của CA để hỏi trạng thái một chứng thư cụ thể và nhận về kết quả good, revoked hoặc unknown.

2.6. Các lỗi chứng thư và cấu hình thường gặp

Bảng 3. Các lỗi chứng thư và cấu hình TLS thường gặp

Lỗi	Nguyên nhân thường gặp	Hậu quả
Chứng thư hết hạn	Quên gia hạn, gia hạn nhưng chưa cài lên máy chủ	Trình duyệt chặn truy cập, dịch vụ gián đoạn
Sai tên miền	Cấp cho tên khác, thiếu tên trong SAN	Trình duyệt báo lỗi; dấu hiệu giả mạo
Tự ký / CA không tin cậy	Dùng chứng thư thử nghiệm, CA nội bộ chưa được tin cậy	Không xác thực được máy chủ, dễ bị tấn công xen giữa
Thiếu chứng thư trung gian	Cấu hình chỉ trỏ tới chứng thư lá	Một số máy khách, ứng dụng di động báo lỗi
Khóa yếu, ký bằng SHA-1/MD5	Chứng thư cũ, công cụ tạo khóa mặc định cũ	Có nguy cơ bị bẻ khóa hoặc giả mạo chữ ký
Bật TLS 1.0/1.1, cipher yếu	Máy chủ cũ, cấu hình mặc định chưa cập nhật	Dễ bị các tấn công hạ cấp và giải mã
Không có Forward Secrecy, HSTS	Thiếu khai báo danh sách cipher, thiếu header	Lộ dữ liệu cũ khi lộ khóa; bị hạ cấp xuống HTTP
Chứng thư bị thu hồi	Khóa riêng bị lộ, CA thu hồi	Máy chủ đang dùng chứng thư không còn giá trị

2.7. Các lỗ hổng ứng dụng web liên quan đến hệ thống

Vì CertGuard là một ứng dụng web có quyền kết nối tới nhiều máy chủ, nhóm đặc biệt quan tâm tới các lỗ hổng sau (tham khảo OWASP Top 10):

- **SSRF (Server-Side Request Forgery):** kẻ tấn công lợi dụng chức năng "nhập địa chỉ để máy chủ kết nối tới" nhằm buộc máy chủ truy cập vào các địa chỉ nội bộ như `127.0.0.1`, `192.168.x.x` hoặc dịch vụ metadata của máy chủ cloud `169.254.169.254`. Đây là rủi ro đặc thù của mọi công cụ quét URL.
- **Dò mật khẩu (brute-force):** thử liên tục nhiều mật khẩu cho một tài khoản.
- **CSRF:** lừa trình duyệt của người dùng đã đăng nhập gửi yêu cầu thay đổi dữ liệu tới hệ thống.
- **XSS:** chèn mã JavaScript vào trang. Với CertGuard, dữ liệu trong chứng thư (tên chủ thể, tên miền) do máy chủ lạ cung cấp nên phải được coi là dữ liệu không tin cậy.
- **SQL Injection:** chèn câu lệnh SQL thông qua dữ liệu đầu vào.

2.8. Công nghệ sử dụng

Bảng 4. Các công nghệ sử dụng trong đề tài

Công nghệ	Vai trò trong hệ thống
Python 3	Ngôn ngữ lập trình chính
Thư viện ssl, socket	Kết nối TCP và bắt tay TLS, thăm dò phiên bản giao thức và bộ mã hóa
Thư viện cryptography	Phân tích chứng thư X.509, xác thực chuỗi tin cậy theo chuẩn Web PKI, truy vấn OCSP, đọc CRL, sinh chứng thư cho môi trường thử nghiệm
certifi	Kho Root CA của Mozilla dùng làm kho tin cậy mặc định
Flask, Jinja2	Framework web và bộ sinh giao diện (tự động escape chống XSS)
SQLite	Cơ sở dữ liệu lưu danh mục máy chủ, kết quả quét, cảnh báo, nhật ký
APScheduler	Lập lịch quét định kỳ
smtplib	Gửi email cảnh báo qua SMTP với STARTTLS
Docker, Nginx	Dựng các web server thật dùng làm môi trường kiểm thử

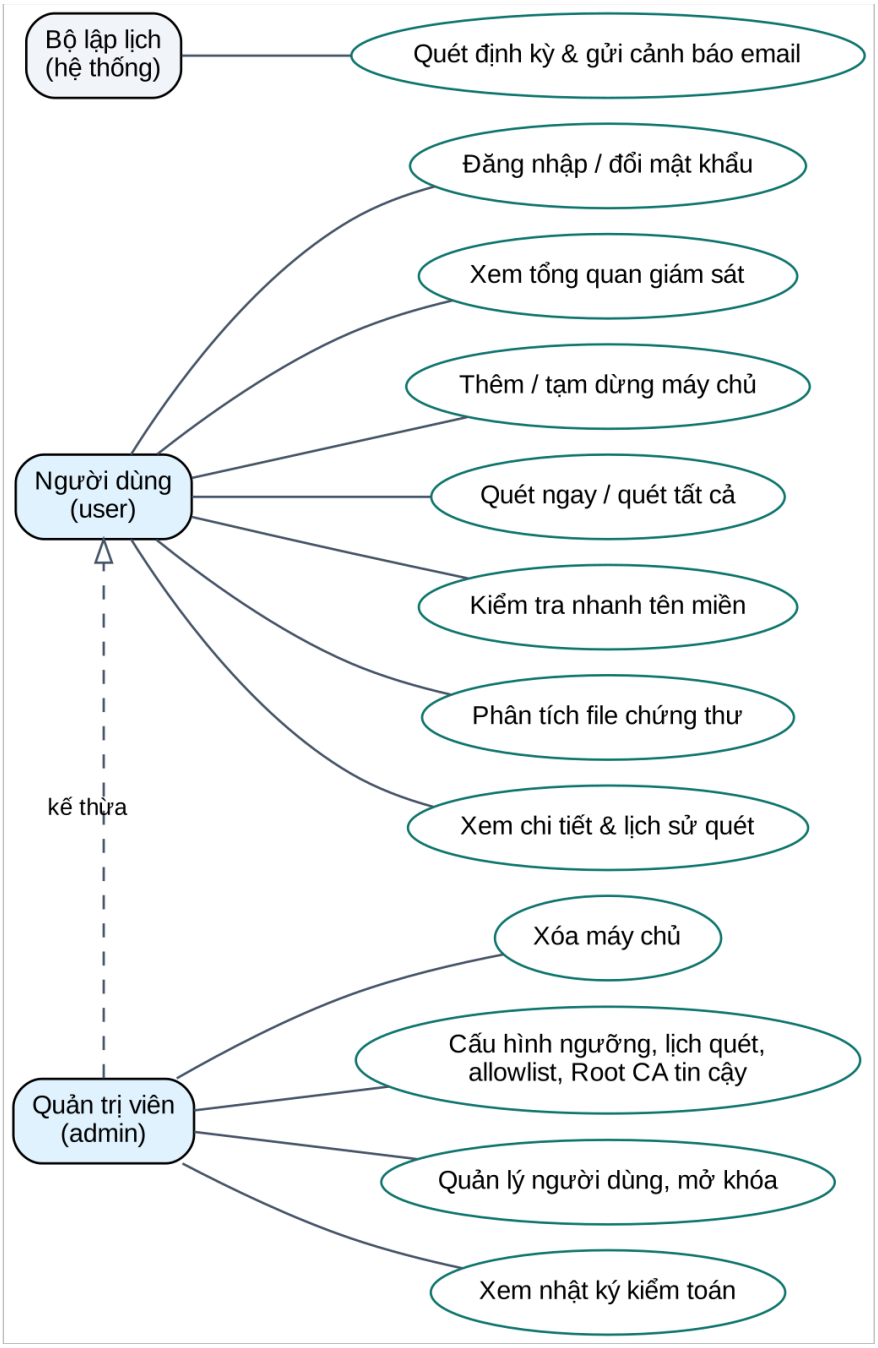
Công nghệ	Vai trò trong hệ thống
OpenSSL, Google Chrome	Công cụ độc lập dùng để đối chứng kết quả

CHƯƠNG 3: PHÂN TÍCH VÀ THIẾT KẾ HỆ THỐNG

3.1. Phân tích yêu cầu

3.1.1. Tác nhân và chức năng

Hệ thống có hai vai trò người dùng là **quản trị viên (admin)** và **người dùng (user)**, cùng một tác nhân hệ thống là **bộ lập lịch** thực hiện quét định kỳ. Quản trị viên có toàn bộ quyền của người dùng và thêm các quyền quản trị.



Hình 2. Sơ đồ tác nhân và chức năng (use case) của hệ thống

Bảng 5. Danh sách chức năng của hệ thống

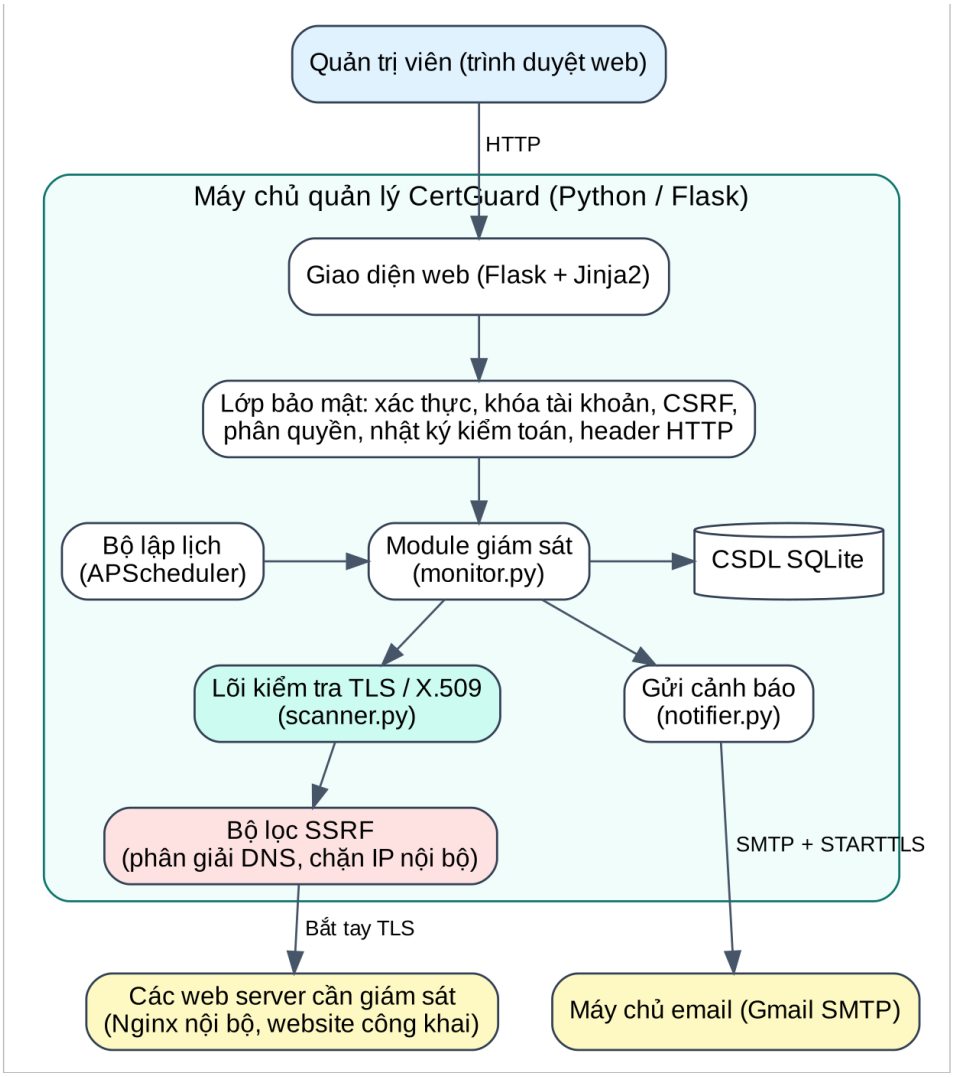
STT	Chức năng	Mô tả	Vai trò
1	Đăng nhập, đổi mật khẩu	Xác thực người dùng; khóa tạm khi nhập sai nhiều lần	Tất cả
2	Tổng quan giám sát	Thống kê trạng thái, danh sách máy chủ, chứng thư sắp hết hạn, cảnh báo gần đây	Tất cả
3	Quản lý máy chủ	Thêm, tạm dừng/bật giám sát; xóa máy chủ	Tất cả / admin (xóa)
4	Quét chứng thư	Quét ngay một máy chủ hoặc quét lại tất cả	Tất cả
5	Kiểm tra nhanh	Kiểm tra một tên miền/URL bất kỳ, có thể thêm vào danh mục	Tất cả
6	Chi tiết và lịch sử	Kết quả phân tích, chuỗi chứng thư, cấu hình TLS, lịch sử quét, cảnh báo đã gửi	Tất cả
7	Phân tích file chứng thư	Đọc file .pem/.crt/.der tải lên mà không cần kết nối mạng	Tất cả
8	Cài đặt	Ngưỡng cảnh báo, chu kỳ quét, danh sách cho phép, Root CA tin cậy, gửi thử cảnh báo	Admin
9	Quản lý người dùng	Tạo, xóa tài khoản, mở khóa tài khoản bị khóa	Admin
10	Nhật ký kiểm toán	Xem lịch sử các thao tác và sự kiện bảo mật	Admin
11	Quét định kỳ và cảnh báo	Tự động quét theo chu kỳ, gửi email khi phát hiện lỗi nghiêm trọng	Hệ thống

3.1.2. Yêu cầu phi chức năng

- **Tính xác thực của dữ liệu:** mọi kết quả được thu thập trực tiếp qua bắt tay TLS với máy chủ đang chạy; cơ sở dữ liệu ban đầu hoàn toàn trống.
- **An toàn:** hệ thống phải chống được các tấn công nêu ở mục 2.7; thông tin bí mật không nằm trong mã nguồn hay cơ sở dữ liệu.
- **Không xâm lấn:** không cài đặt gì lên máy chủ được kiểm tra (agentless); máy chủ chỉ cần mở cổng HTTPS.
- **Dễ triển khai:** chạy trên một máy với Python, không cần máy chủ cơ sở dữ liệu riêng.
- **Dễ sử dụng:** giao diện tiếng Việt, kết quả có màu sắc theo mức độ nghiêm trọng, có lệnh đối chứng OpenSSL kèm theo.

3.2. Kiến trúc tổng thể

CertGuard được thiết kế theo mô hình **web tập trung, không dùng tác tử**: một máy chủ quản lý trung tâm chủ động kết nối tới các web server cần giám sát; quản trị viên thao tác qua trình duyệt. Đây cũng là mô hình của nhiều công cụ giám sát chứng thư thực tế. Các web server được kiểm tra hoàn toàn độc lập với CertGuard và có thể đặt ở bất kỳ đâu, miễn là CertGuard kết nối được qua mạng.



Hình 3. Kiến trúc tổng thể của hệ thống CertGuard

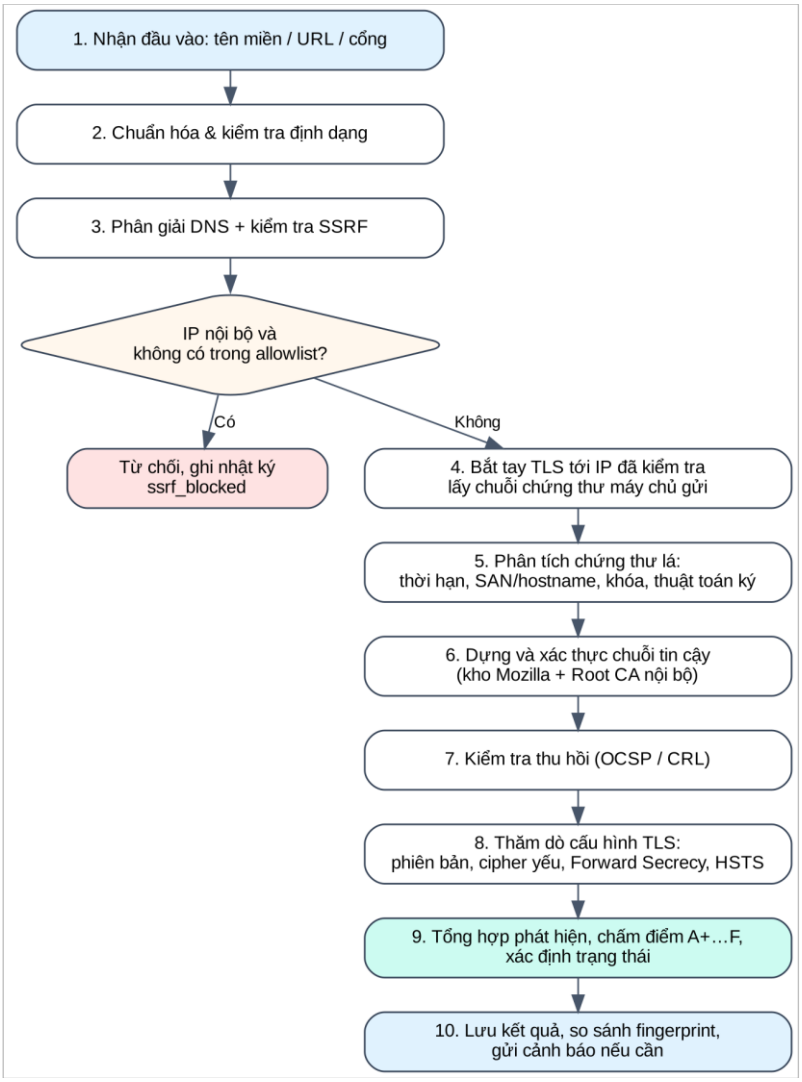
Bảng 6. Các thành phần của hệ thống

Thành phần	Tệp mã nguồn	Nhiệm vụ
Lõi kiểm tra	scanner.py	Chuẩn hóa đầu vào, chống SSRF, bắt tay TLS, phân tích chứng thư, xác thực chuỗi, kiểm tra thu hồi, thăm dò cấu hình TLS, chấm điểm

Thành phần	Tệp mã nguồn	Nhiệm vụ
Giám sát	monitor.py	Quét một hoặc nhiều máy chủ song song, lưu kết quả, phát hiện chứng thư thay đổi, quyết định gửi cảnh báo, chống gửi lặp
Cảnh báo	notifier.py	Gửi email qua SMTP + STARTTLS (và Telegram nếu cấu hình)
Bảo mật	security.py	Băm mật khẩu, xác thực và khóa tài khoản, CSRF, phân quyền, nhật ký, header bảo mật
Dữ liệu	db.py	Lược đồ và truy vấn SQLite có tham số
Ứng dụng web	app.py, templates/	Định tuyến, giao diện, lập lịch quét định kỳ
Quản trị dòng lệnh	manage.py	Tạo tài khoản admin, làm mới cơ sở dữ liệu, thống kê

3.3. Luồng xử lý kiểm tra chứng thư

Mỗi lần kiểm tra một máy chủ (thủ công hoặc định kỳ) đều đi qua cùng một luồng xử lý trong `scanner.py`:



Hình 4. Luồng xử lý một lần kiểm tra chứng thư

- **Bước 1–2:** nhận tên miền, `tên_miền:cổng` hoặc URL; tách lấy tên máy chủ và cổng; từ chối các lược đồ khác `http/https` và tên miền sai định dạng.
- **Bước 3:** phân giải DNS; nếu bất kỳ địa chỉ nào không phải IP công cộng mà tên miền không nằm trong danh sách cho phép thì từ chối (chống SSRF). Hệ thống kết nối thẳng tới IP đã kiểm tra để tránh tấn công DNS rebinding.
- **Bước 4:** bắt tay TLS với SNI là tên miền, ở chế độ **không tự động xác thực** để nhận được cả những chứng thư lỗi; việc xác thực được thực hiện riêng ở các bước sau để biết chính xác lỗi là gì.
- **Bước 5–6:** phân tích chứng thư lá và dựng lại đường đi lá → trung gian → gốc; phân loại tình huống tự ký, Root CA không tin cậy hoặc thiếu chuỗi; sau đó xác thực đầy đủ bằng bộ xác thực Web PKI của thư viện cryptography.

- **Bước 7:** nếu chứng thư khai báo OCSP hoặc CRL thì truy vấn trạng thái thu hồi. Địa chỉ OCSP/CRL nằm trong chứng thư do máy chủ lạ gửi nên cũng được kiểm tra SSRF.
- **Bước 8:** thử bắt tay lần lượt với TLS 1.0, 1.1, 1.2, 1.3; thử với các cipher yếu; thử với trao đổi khóa RSA tĩnh; đọc header HSTS.
- **Bước 9–10:** tổng hợp các phát hiện, chấm điểm, lưu kết quả, so sánh fingerprint với lần quét trước và gửi cảnh báo nếu cần.

3.4. Quy tắc đánh giá và chấm điểm

Mỗi phát hiện có một **mức độ nghiêm trọng** và có thể kèm một **điểm tối đa**. Điểm khởi đầu là A+, mỗi phát hiện giới hạn điểm không vượt quá mức tương ứng; máy chủ không có HSTS thì tối đa đạt A. Cách chấm này tương tự nguyên tắc của các công cụ đánh giá TLS phổ biến.

Bảng 7. Quy tắc chấm điểm của CertGuard

Phát hiện	Mức độ	Điểm tối đa
Chứng thư hết hạn hoặc chưa có hiệu lực	Nghiêm trọng	F
Sai tên miền; thiếu SAN	Nghiêm trọng / Cao	F
Chứng thư tự ký; Root CA không tin cậy	Nghiêm trọng	F
Bị thu hồi (OCSP/CRL); ký bằng MD5 hoặc SHA-1	Nghiêm trọng	F
Không hỗ trợ TLS 1.2 và TLS 1.3	Cao	F
Khóa RSA < 2048 bit (≥ 1024); ECDSA < 256 bit	Cao	C
Chấp nhận cipher yếu (3DES, RC4, NULL…)	Cao	C
Thiếu chứng thư trung gian	Cao	B
Còn bật TLS 1.0 / TLS 1.1	Trung bình	B
Không có Forward Secrecy	Trung bình	B
Không có HSTS	Thấp	A
Còn ≤ 7 ngày / ≤ 30 ngày là hết hạn	Cao / Trung bình	Không trừ điểm
Chưa bật TLS 1.3; thời hạn > 398 ngày	Thấp	Không trừ điểm

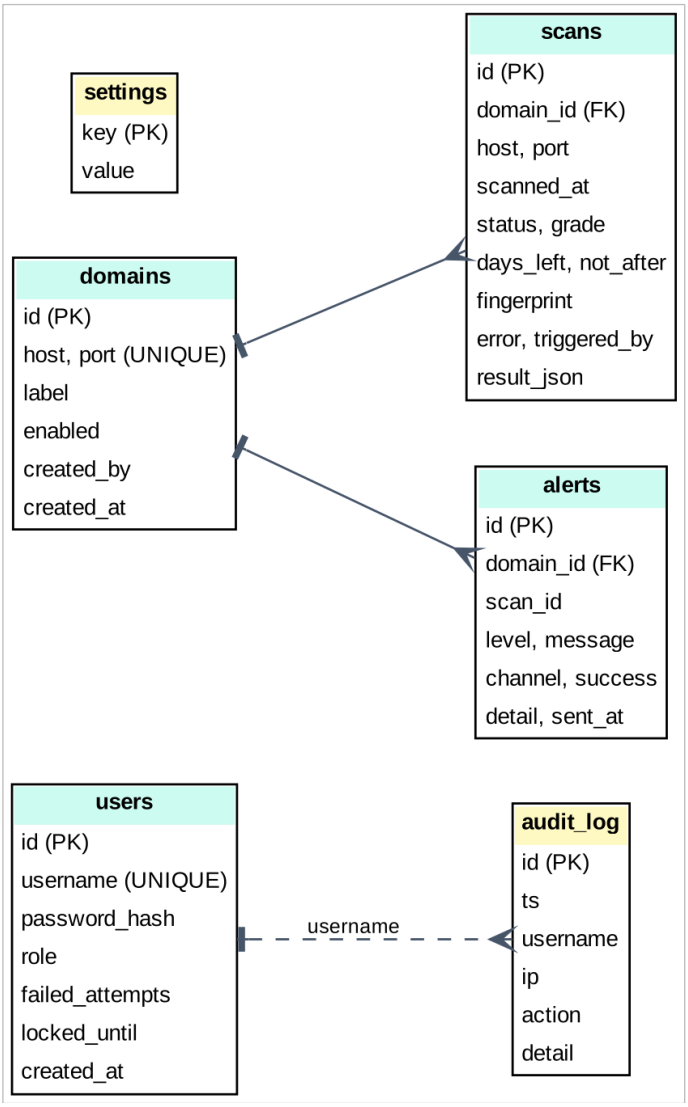
Ngoài điểm, mỗi lần quét có một **trạng thái**: Lỗi khi có phát hiện nghiêm trọng, Cảnh báo khi có phát hiện mức cao hoặc trung bình, Hợp lệ khi không có vấn đề đáng kể, và Mất kết nối khi không bắt tay được với máy chủ. Điểm phản ánh chất lượng cấu

hình, còn trạng thái cho biết mức độ cần xử lý; ví dụ chứng thư sắp hết hạn vẫn có thể đạt A+ nhưng ở trạng thái Cảnh báo.

3.5. Giám sát định kỳ và cảnh báo

- Bộ lập lịch quét lại toàn bộ máy chủ đang bật giám sát theo chu kỳ cấu hình được (mặc định 1440 phút, tức một ngày). Các máy chủ được quét song song, mỗi luồng dùng kết nối cơ sở dữ liệu riêng.
- Mỗi lần quét so sánh fingerprint SHA-256 của chứng thư với lần trước để phát hiện **chứng thư bị thay đổi**.
- Email cảnh báo được gửi khi có các lỗi cần xử lý ngay: hết hạn, sắp hết hạn, tự ký, CA không tin cậy, sai tên miền, thiếu chuỗi, bị thu hồi, ký bằng thuật toán yếu, mất kết nối hoặc chứng thư thay đổi. Các lỗi cấu hình nhẹ chỉ hiển thị trên giao diện để tránh làm phiền.
- Với quét định kỳ, cùng một nội dung cảnh báo không được gửi lặp lại trong khoảng thời gian chờ (mặc định 60 phút). Mọi lần gửi, thành công hay thất bại, đều được lưu lại.

3.6. Thiết kế cơ sở dữ liệu



Hình 5. Sơ đồ cơ sở dữ liệu của hệ thống

Bảng 8. Mô tả các bảng trong cơ sở dữ liệu

Bảng	Nội dung lưu trữ
users	Tài khoản: tên đăng nhập, mật khẩu đã băm, vai trò, số lần đăng nhập sai, thời điểm hết khóa
domains	Danh mục máy chủ cần giám sát: tên miền, cổng, ghi chú, trạng thái bật/tắt, người tạo
scans	Kết quả từng lần quét: trạng thái, điểm, số ngày còn lại, ngày hết hạn, fingerprint, lỗi, kiểu quét và toàn bộ kết quả chi tiết dạng JSON
alerts	Các cảnh báo đã gửi: mức độ, nội dung, kênh gửi, kết quả gửi
audit_log	Nhật ký kiểm toán: thời điểm, người dùng, địa chỉ IP, hành động, chi tiết
settings	Cấu hình: ngưỡng cảnh báo, chu kỳ quét, thời gian chờ cảnh báo, danh sách cho phép

3.7. Thiết kế bảo mật cho hệ thống

Bảng dưới đây tổng hợp các mối đe dọa đối với chính CertGuard và biện pháp tương ứng đã được thiết kế và cài đặt.

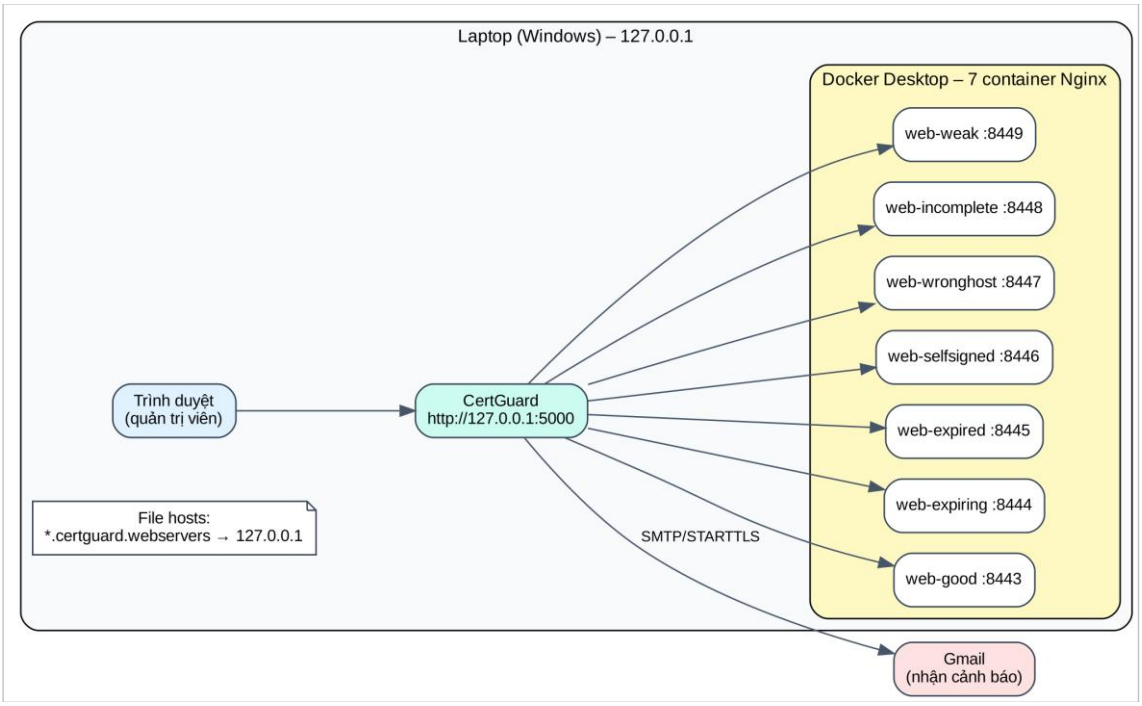
Bảng 9. Các mối đe dọa và biện pháp bảo vệ hệ thống

Mối đe dọa	Biện pháp trong CertGuard
SSRF qua chức năng quét	Phân giải DNS trước, chặn mọi IP không phải IP công cộng (loopback, mạng riêng, link-local, metadata cloud…) trừ tên miền trong danh sách cho phép do admin cấu hình; kết nối thẳng tới IP đã kiểm tra để chống DNS rebinding; áp dụng cả với URL OCSP/CRL trong chứng thư
Dò mật khẩu	Khóa tài khoản 5 phút sau 5 lần đăng nhập sai; thông báo lỗi chung không tiết lộ tài khoản có tồn tại hay không; thời gian xử lý như nhau nhờ băm giả
Lộ mật khẩu khi lộ CSDL	Mật khẩu băm bằng scrypt có salt ngẫu nhiên; chính sách mật khẩu tối thiểu 8 ký tự gồm chữ và số
CSRF	Mọi form POST mang token ngẫu nhiên gắn với phiên, so sánh bằng hàm thời gian hằng; cookie phiên HttpOnly, SameSite=Lax
XSS (kể cả qua dữ liệu chứng thư)	Jinja2 tự động escape mọi dữ liệu; Content-Security-Policy chỉ cho phép script từ chính hệ thống, không có script nội dòng
SQL Injection	Mọi truy vấn dùng tham số (placeholder ?)
Session fixation, clickjacking	Làm mới phiên khi đăng nhập; header X-Frame-Options: DENY, frame-ancestors 'none'
Leo thang đặc quyền	Phân quyền admin/user kiểm tra ở phía máy chủ cho từng chức năng
Lộ thông tin bí mật	Secret key sinh ngẫu nhiên lưu trong thư mục instance; mật khẩu email đặt trong tệp .env, không nằm trong mã nguồn hay CSDL
Tải tệp độc hại, path traversal	Giới hạn kích thước tải lên 1 MB; chỉ đọc tệp trong bộ nhớ; tên tệp Root CA được lọc ký tự và kiểm tra nằm trong đúng thư mục
Chối bỏ hành vi	Nhật ký kiểm toán ghi lại đăng nhập, khóa tài khoản, chặn SSRF, thêm/xóa máy chủ, thay đổi cài đặt, quản lý người dùng

CHƯƠNG 4: CÀI ĐẶT VÀ KẾT QUẢ THỰC NGHIỆM

4.1. Môi trường thực nghiệm

Toàn bộ hệ thống được triển khai trên **một máy tính** chạy Windows. CertGuard chạy trực tiếp bằng Python tại địa chỉ `http://127.0.0.1:5000`; bảy web server Nginx thật chạy trong Docker Desktop, mỗi máy chủ nghe trên một cổng riêng. Tệp hosts của Windows được khai báo để các tên miền `*.certguard.webservers` trỏ về máy cục bộ. Trong triển khai thực tế, CertGuard được đặt trên một máy chủ nội bộ và giám sát các web server của tổ chức qua mạng.



Hình 6. Mô hình môi trường thực nghiệm trên một máy tính

Bảng 10. Môi trường cài đặt và thực nghiệm

Thành phần	Cấu hình / phiên bản
Hệ điều hành	Windows 10/11
Ngôn ngữ, thư viện	Python 3.10+, Flask 3, cryptography, APScheduler, certifi
Web server kiểm thử	Docker Desktop, image nginx:1.27-alpine (7 container)
Công cụ đối chứng	OpenSSL (Git Bash), Google Chrome
Kênh cảnh báo	Gmail SMTP (smtp.gmail.com:587, STARTTLS, mật khẩu ứng dụng)

4.2. Xây dựng các web server kiểm thử

Để kết quả kiểm thử phản ánh đúng thực tế, nhóm không nhập sẵn dữ liệu vào cơ sở dữ liệu mà dựng các web server thật với các lỗi thật. Script `gen_certs.py` đóng vai một CA nội bộ: tạo Root CA "CertGuard Internal Root CA" (RSA 4096), CA trung gian "CertGuard Internal Issuing CA" và ký chứng thư cho từng máy chủ. Tệp `docker-compose.yml` khởi động bảy container Nginx, mỗi container gắn một chứng thư và một tệp cấu hình TLS.

Bảng 11. Bảy web server kiểm thử và kết quả mong đợi

Máy chủ (cổng)	Tình huống được cấu hình	Kết quả mong đợi
good (8443)	Chứng thư hợp lệ; chỉ TLS 1.2/1.3; cipher có Forward Secrecy theo khuyến nghị Mozilla; bật HSTS	Hợp lệ, A+
expiring (8444)	Chứng thư chỉ còn 5 ngày hiệu lực	Cảnh báo sắp hết hạn
expired (8445)	Chứng thư đã hết hạn 10 ngày	Lỗi, F
selfsigned (8446)	Chứng thư tự ký, không do CA nào cấp	Lỗi, F
wronghost (8447)	Chứng thư cấp cho khac.certguard.webservers	Lỗi sai tên miền, F
incomplete (8448)	Máy chủ không gửi chứng thư trung gian	Cảnh báo thiếu chuỗi, B
weak (8449)	Khóa RSA 1024 bit; bật TLS 1.0/1.1; cipher yếu; không HSTS	Cảnh báo, C

[CHÈN ẢNH CHỤP MÀN HÌNH]
Docker Desktop hiển thị 7 container web-good, web-expiring, web-expired, web-selfsigned, web-wronghost, web-incomplete, web-weak đang chạy (Running)
(Xóa khung này và dán ảnh vào đây)

Hình 7. Bảy web server Nginx đang chạy trong Docker Desktop

4.3. Cài đặt các module chính

4.3.1. Chống SSRF khi phân giải tên miền

Hàm `resolve_safe()` phân giải tên miền, kiểm tra mọi địa chỉ IP trả về và chỉ cho phép địa chỉ nội bộ khi tên miền khớp danh sách cho phép. Địa chỉ IP đã kiểm tra được dùng trực tiếp để kết nối, nhờ đó kẻ tấn công không thể đổi bản ghi DNS giữa lúc kiểm tra và lúc kết nối.

```
def resolve_safe(host, port, allowlist):
    infos = socket.getaddrinfo(host, port, type=socket.SOCK_STREAM)
    ips = list(dict.fromkeys(i[4][0] for i in infos))
    internal = [ip for ip in ips if not ipaddress.ip_address(ip).is_global]
    if internal and not host_allowed(host, allowlist):
        raise BlockedTarget(f"Đã chặn: '{host}' trỏ tới địa chỉ nội bộ ... (chống
SSRF)")
    ips.sort(key=lambda ip: ":" in ip)      # ưu tiên IPv4
    return ips[0]                             # kết nối thẳng tới IP đã kiểm tra
```

Hình 8. Hàm phân giải tên miền có kiểm tra SSRF (scanner.py)

4.3.2. Bắt tay TLS và lấy chuỗi chứng thư

CertGuard bắt tay TLS ở chế độ không xác thực để nhận về nguyên vẹn chuỗi chứng thư mà máy chủ gửi, kể cả khi chứng thư bị lỗi. Với Python 3.13 trở lên, chuỗi được lấy bằng `get_unverified_chain()`; với phiên bản cũ hơn, hệ thống dùng pyOpenSSL. Mức bảo mật của OpenSSL phía máy khách được hạ xuống (`@SECLEVEL=0`) chỉ trong lúc thăm dò, để có thể phát hiện các máy chủ còn chấp nhận giao thức và khóa yếu.

```
ctx = ssl.SSLContext(ssl.PROTOCOL_TLS_CLIENT)
ctx.check_hostname = False
ctx.verify_mode = ssl.CERT_NONE           # nhận cả chứng thư lỗi để phân tích
ctx.set_ciphers("DEFAULT:@SECLEVEL=0")
with socket.create_connection((ip, port), timeout=timeout) as sock:
    with ctx.wrap_socket(sock, server_hostname=sni) as s:
        chain = s.get_unverified_chain()   # danh sách chứng thư máy chủ gửi
        version, cipher = s.version(), s.cipher()


# Thăm dò từng phiên bản giao thức
for label, v in [("TLS 1.0", TLSv1), ("TLS 1.1", TLSv1_1), ("TLS 1.2", TLSv1_2), ("TLS
1.3", TLSv1_3)]:
    protocols[label] = probe_handshake(ip, port, host, timeout, min_v=v, max_v=v)
```

Hình 9. Bắt tay TLS và thăm dò phiên bản giao thức (scanner.py)

4.3.3. Phân loại lỗi chuỗi tin cậy

Thay vì chỉ trả về "hợp lệ/không hợp lệ", CertGuard dựng lại đường đi của chuỗi theo quan hệ người cấp – người được cấp để chỉ ra chính xác nguyên nhân, sau đó

dùng bộ xác thực Web PKI của thư viện cryptography để xác thực đầy đủ theo RFC 5280.

```
if trusted_root:                                    # lần ngược được tới Root CA tin
cậy
    info["anchor"] = trusted_root.subject.rfc4514_string()
elif is_self_signed(top) and len(path) == 1:
    info["problem"] = "self_signed"               # chứng thư tự ký
elif is_self_signed(top) or len(path) > 1:
    info["problem"] = "untrusted_root"            # Root CA không có trong kho tin cậy
else:
    info["problem"] = "incomplete_chain"          # máy chủ không gửi chứng thư trung
gian

verifier =
PolicyBuilder().store(Store(roots)).time(now).build_server_verifier(DNSName(host))
verifier.verify(leaf, intermediates)              # xác thực đầy đủ chuỗi + tên miền
```

Hình 10. Phân loại lỗi chuỗi tin cậy (scanner.py)

4.3.4. Xác thực, khóa tài khoản và CSRF

```
if check_password_hash(user["password_hash"], password):   # scrypt + salt
    reset failed_attempts, locked_until
    return user
failed = user["failed_attempts"] + 1
if failed >= MAX_FAILED:                                    # 5 lần sai
    locked_until = now + timedelta(minutes=LOCK_MINUTES)    # khóa 5 phút
    audit(conn, "account_locked", ...)

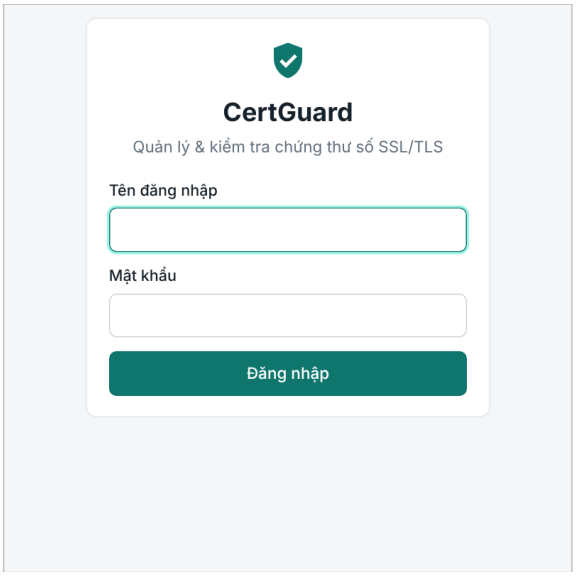
def check_csrf():                                           # chạy trước mọi request
    if request.method == "POST":
        sent = request.form.get("_csrf", "")
        if not sent or not hmac.compare_digest(sent, session.get("_csrf", "")):
            abort(400, "CSRF token không hợp lệ")
```

Hình 11. Khóa tài khoản và kiểm tra CSRF token (security.py)

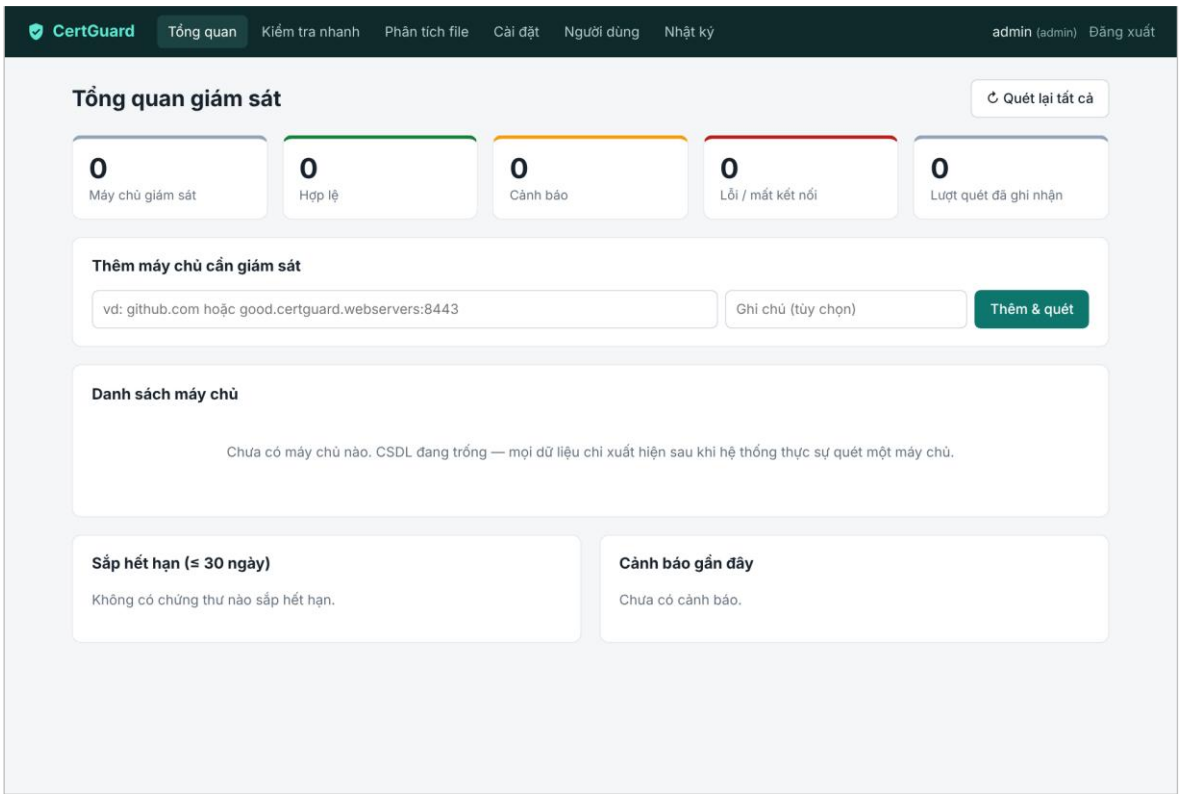
4.4. Giao diện và kết quả kiểm tra

4.4.1. Đăng nhập và trạng thái ban đầu

Người dùng đăng nhập bằng tài khoản do quản trị viên tạo (tài khoản admin đầu tiên được tạo bằng lệnh `python manage.py create-admin`). Ở lần chạy đầu tiên, trang tổng quan hoàn toàn trống: mọi dữ liệu sau đó đều do hệ thống tự thu thập.



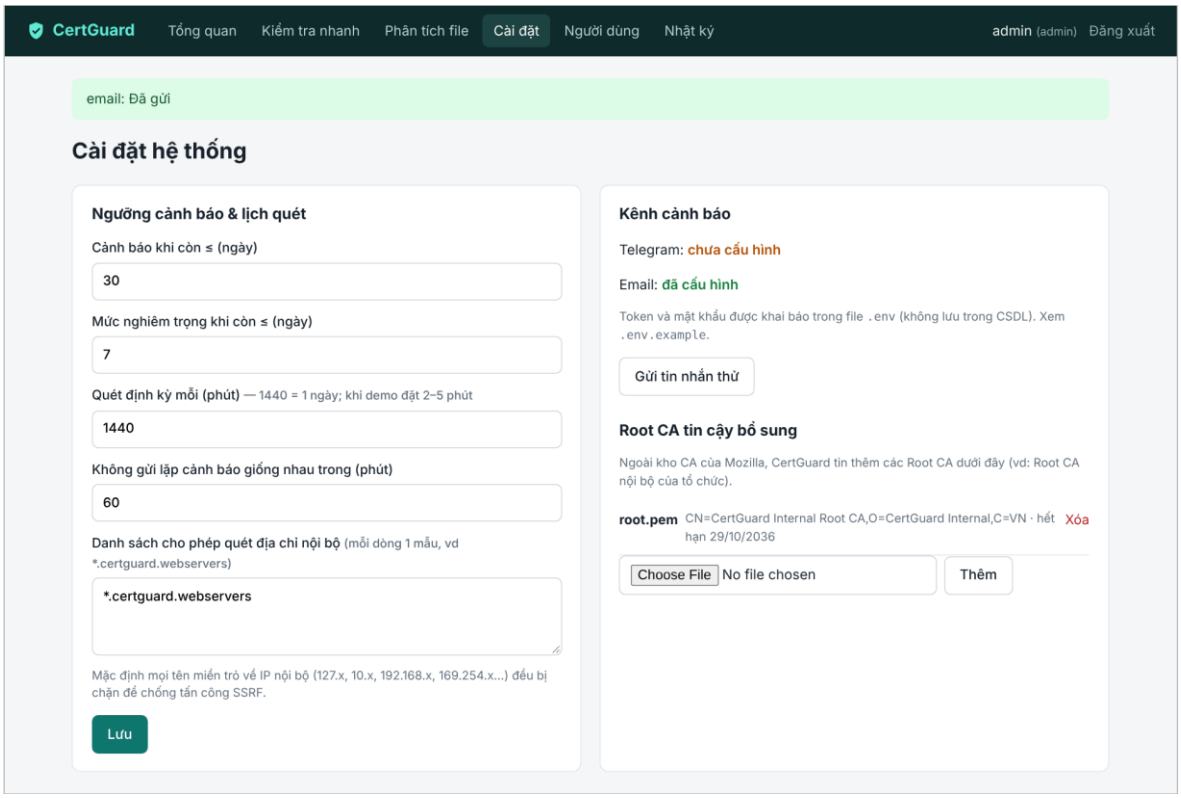
Hình 12. Giao diện đăng nhập



Hình 13. Trang tổng quan khi cơ sở dữ liệu còn trống

4.4.2. Khai báo Root CA nội bộ

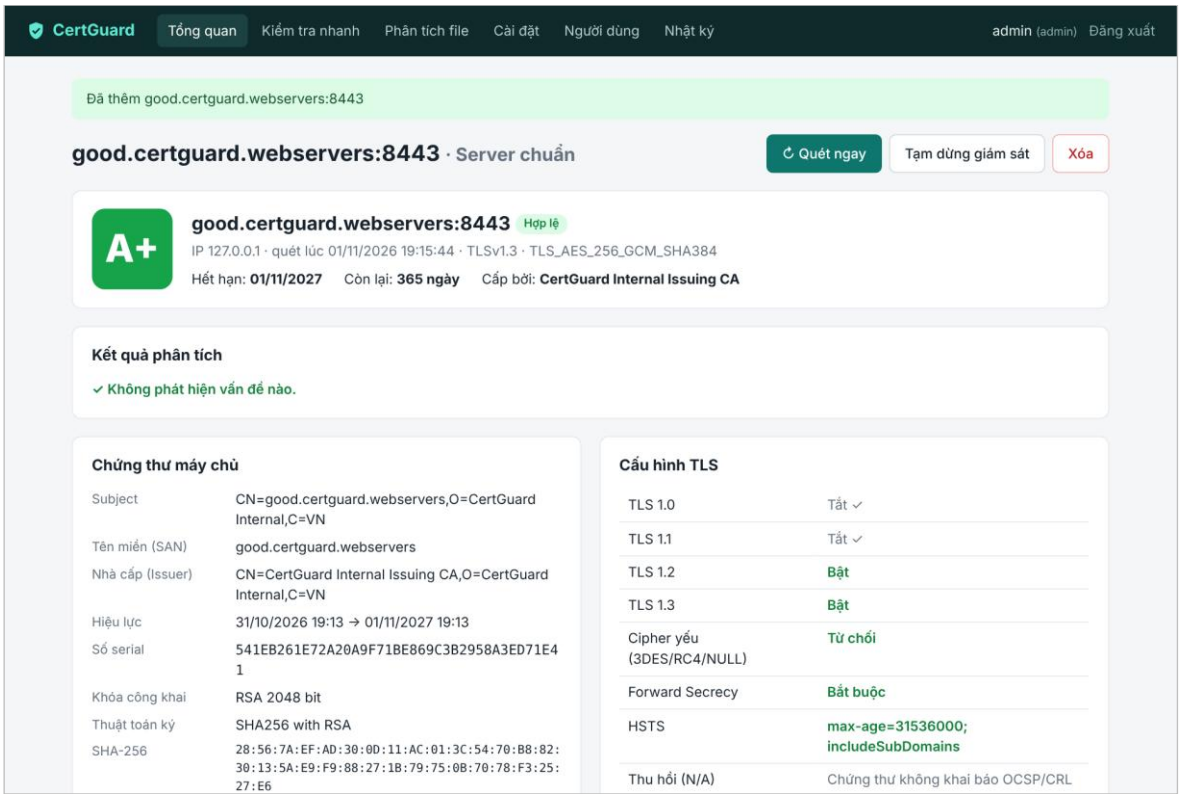
Các web server kiểm thử dùng chứng thư do CA nội bộ cấp. Quản trị viên tải Root CA nội bộ lên trang Cài đặt để CertGuard tin cậy, giống cách doanh nghiệp phân phối Root CA nội bộ cho các máy trong tổ chức. Trang này cũng cho phép cấu hình ngưỡng cảnh báo, chu kỳ quét, danh sách cho phép quét địa chỉ nội bộ và gửi thử email cảnh báo.



Hình 14. Trang cài đặt: Root CA tin cậy, kênh cảnh báo và gửi thử email

4.4.3. Máy chủ cấu hình chuẩn

Máy chủ `good.certguard.webservers:8443` đạt điểm **A+**: chứng thư hợp lệ, chỉ hỗ trợ TLS 1.2 và 1.3, từ chối cipher yếu, bắt buộc Forward Secrecy và có HSTS. Chuỗi chứng thư đi từ chứng thư máy chủ qua CA trung gian lên Root CA vừa khai báo.



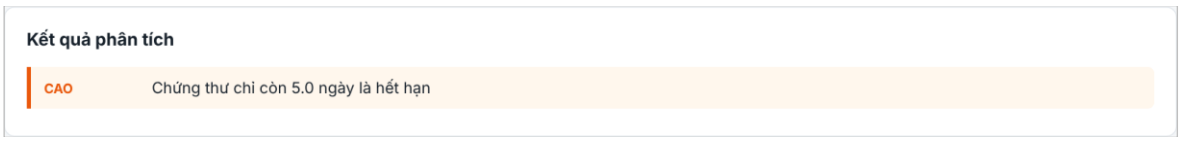
Hình 15. Kết quả kiểm tra máy chủ chuẩn đạt điểm A+



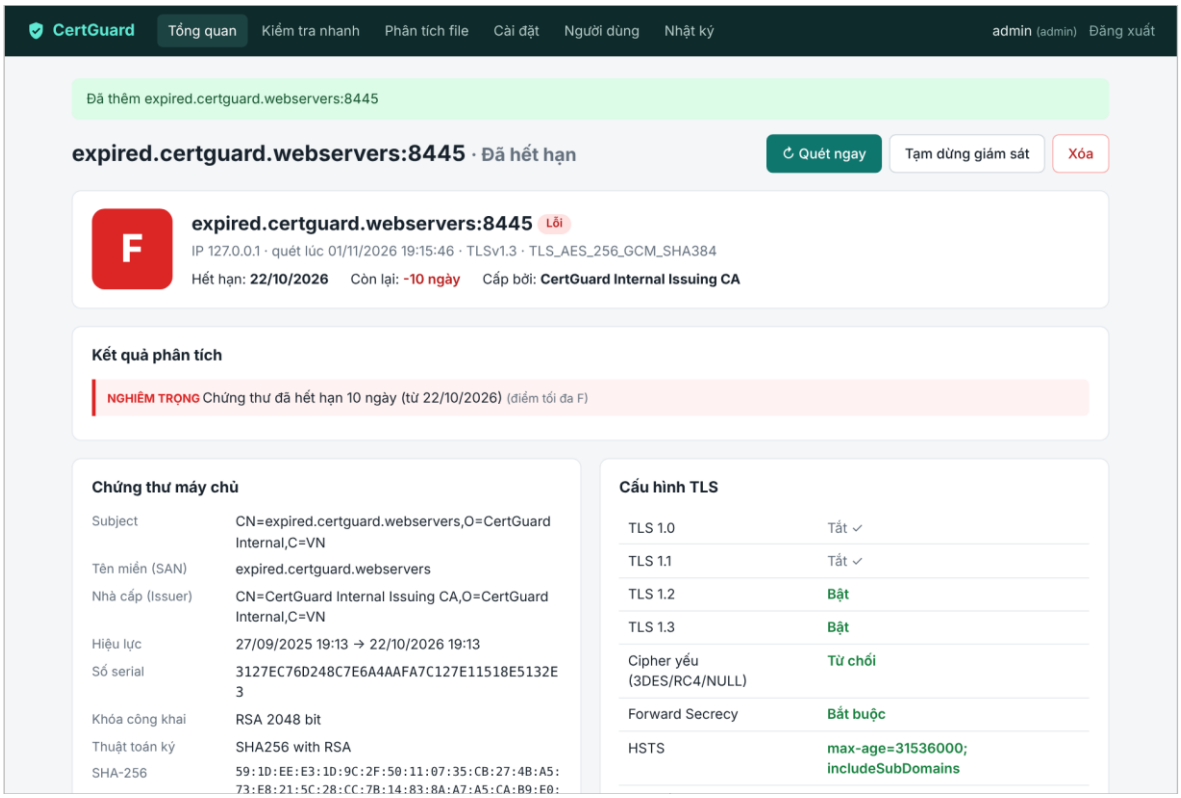
Hình 16. Chuỗi chứng thư của máy chủ chuẩn

4.4.4. Các máy chủ có lỗi

Lần lượt thêm sáu máy chủ còn lại, hệ thống phát hiện đúng lỗi được cấu hình trên từng máy chủ:



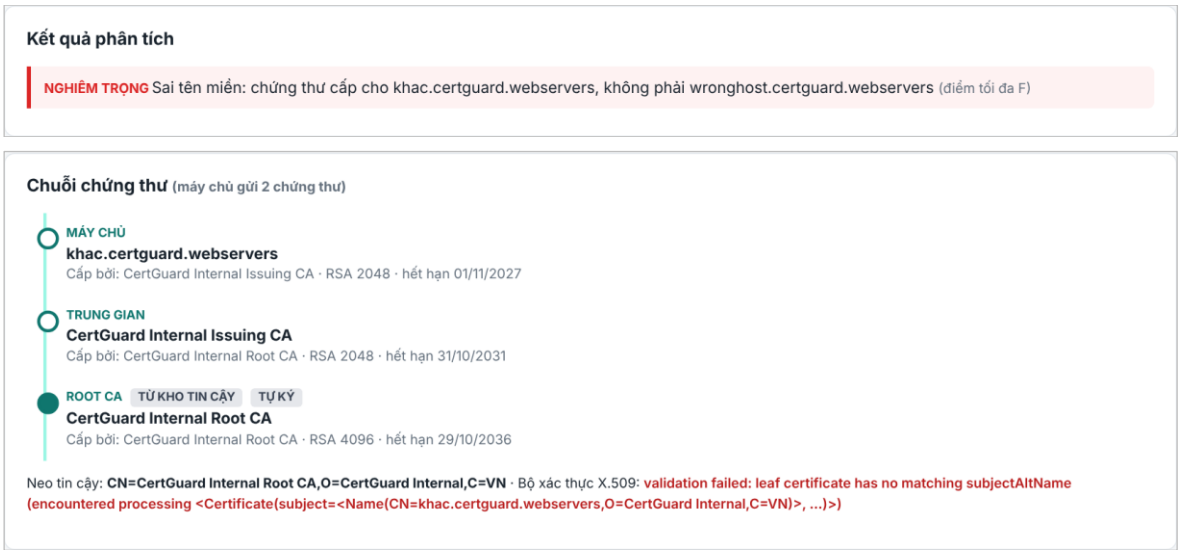
Hình 17. Máy chủ expiring: chứng thư chỉ còn 5 ngày hiệu lực



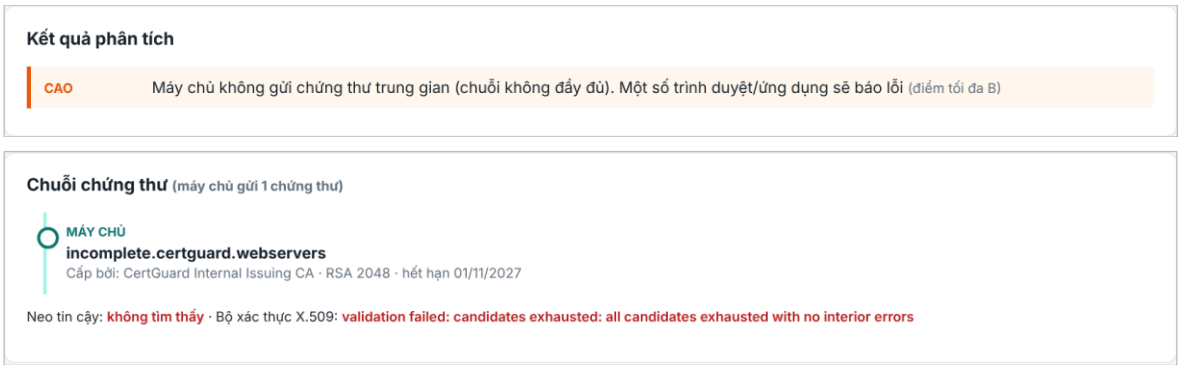
Hình 18. Máy chủ expired: chứng thư đã hết hạn, điểm F



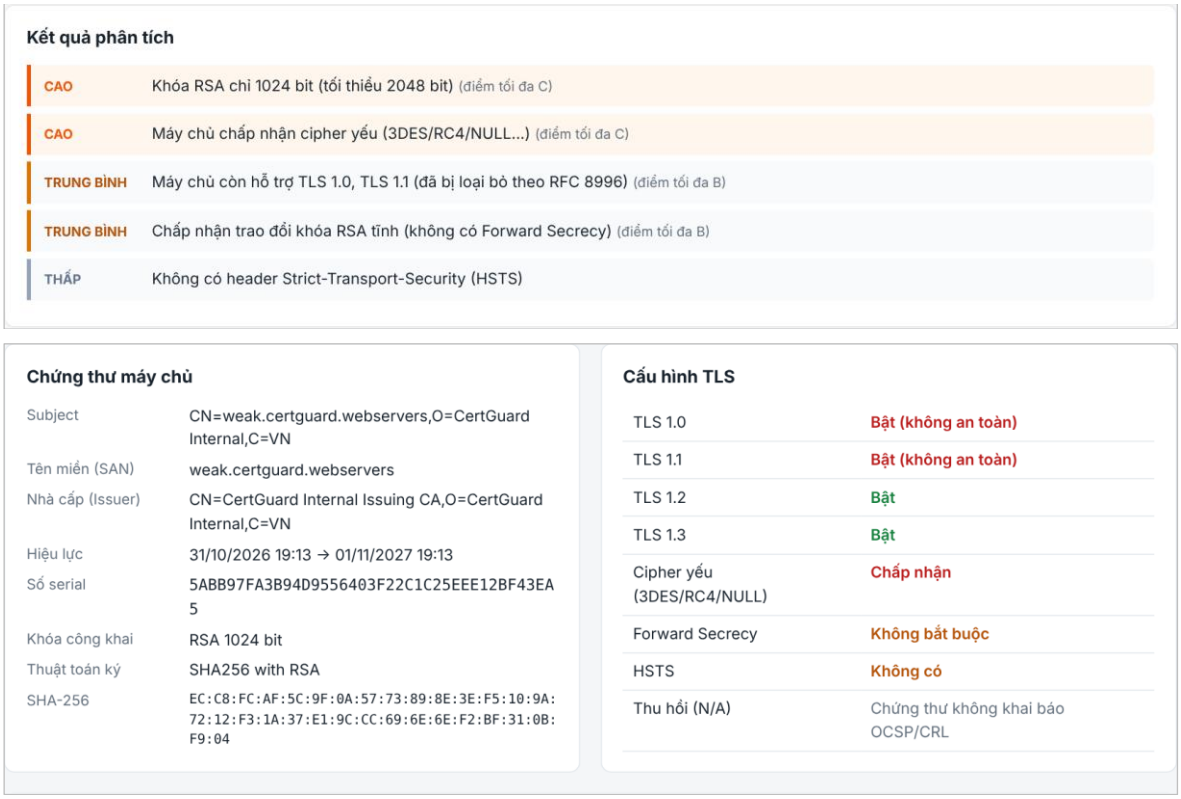
Hình 19. Máy chủ selfsigned: chứng thư tự ký, chuỗi chỉ có một chứng thư



Hình 20. Máy chủ wronghost: chứng thư cấp cho tên miền khác



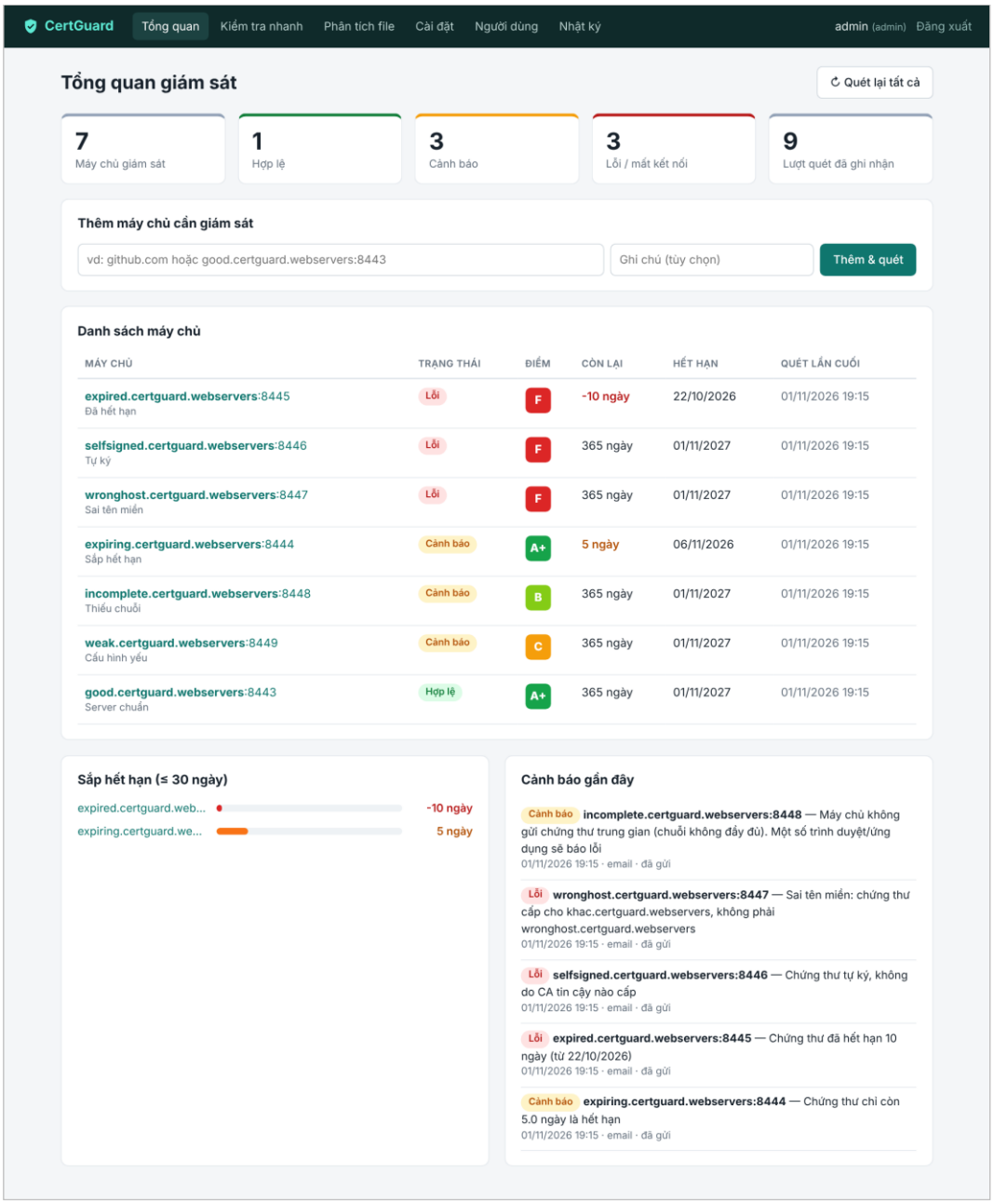
Hình 21. Máy chủ incomplete: máy chủ chỉ gửi một chứng thư, thiếu CA trung gian



Hình 22. Máy chủ weak: khóa RSA 1024 bit, còn bật TLS 1.0/1.1, chấp nhận cipher yếu, không HSTS

4.4.5. Trang tổng quan giám sát

Sau khi thêm đủ bảy máy chủ, trang tổng quan sắp xếp máy chủ theo mức độ cần xử lý, thống kê số máy chủ hợp lệ, cảnh báo, lỗi; hiển thị các chứng thư sắp hết hạn và danh sách cảnh báo đã gửi.



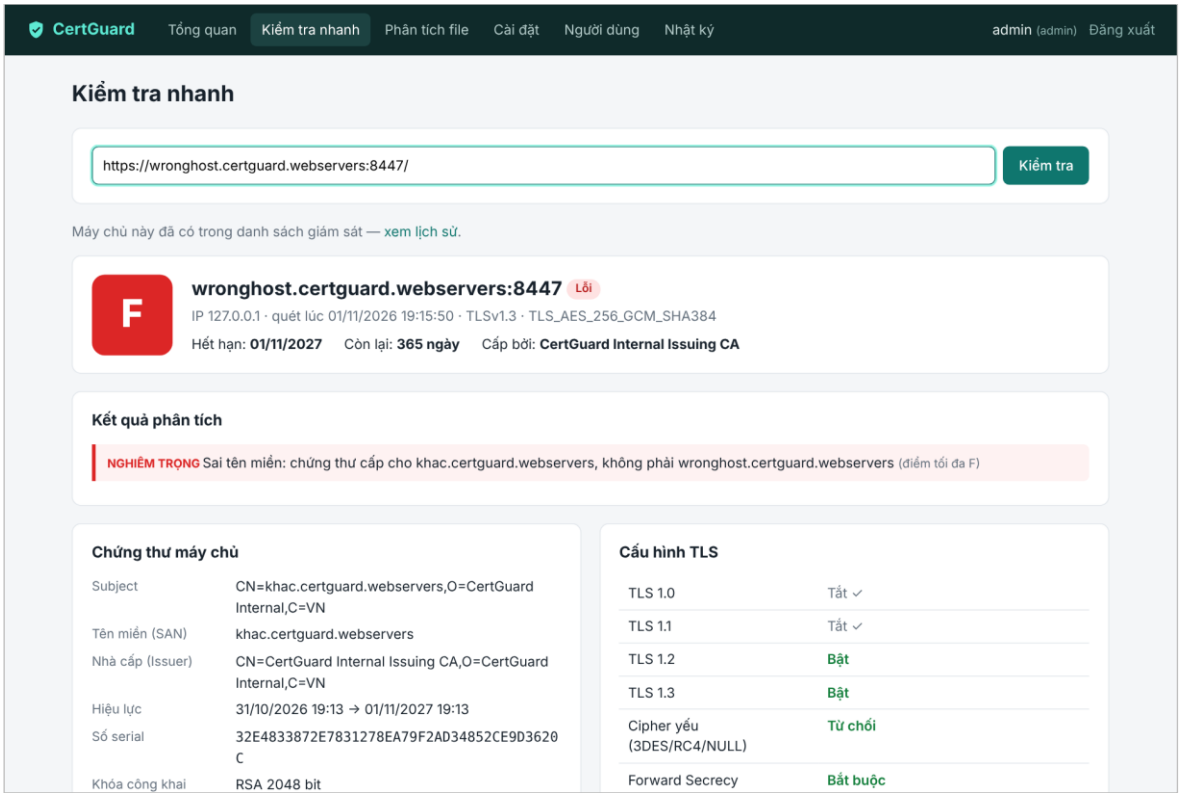
Hình 23. Trang tổng quan sau khi giám sát bảy máy chủ

4.4.6. Lịch sử quét, kiểm tra nhanh và phân tích file

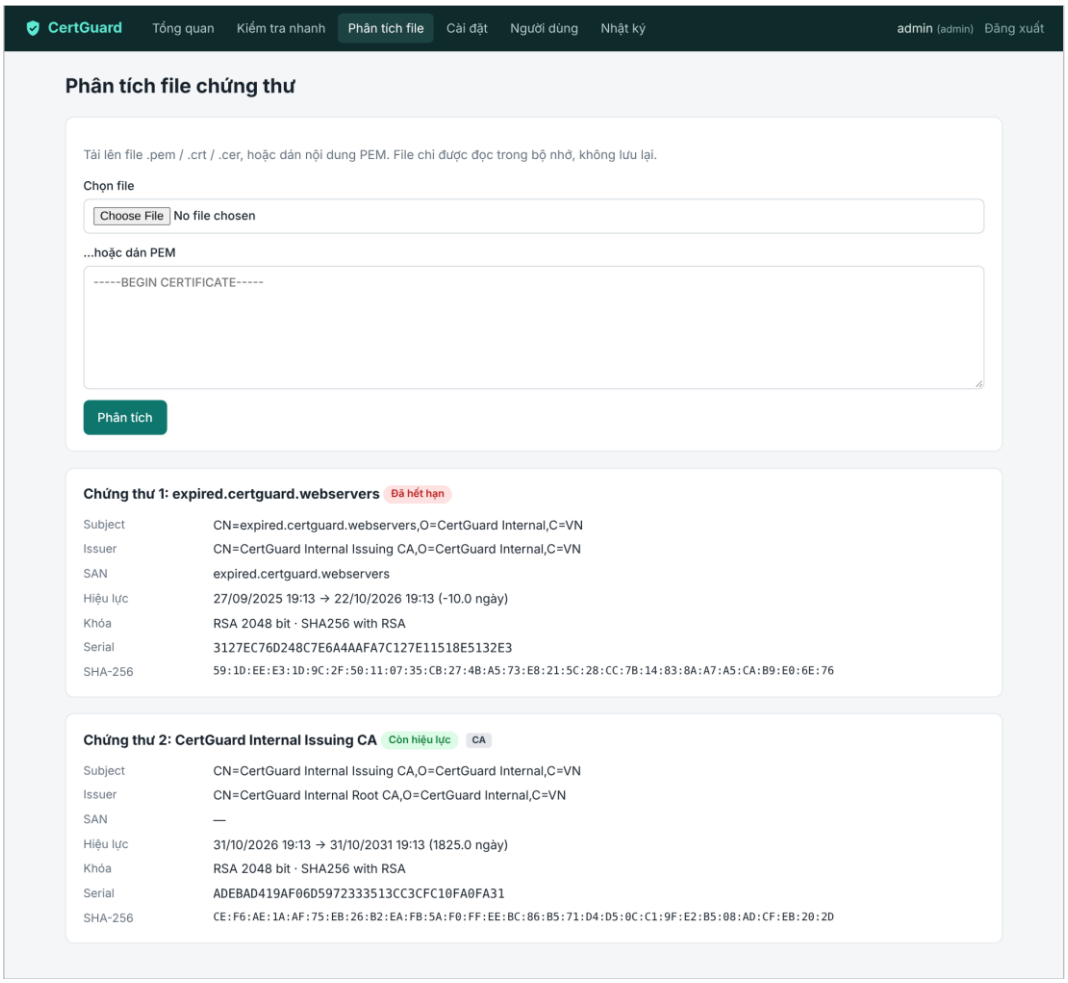
Mỗi máy chủ lưu lại lịch sử các lần quét kèm fingerprint; khi fingerprint thay đổi, hệ thống đánh dấu và gửi cảnh báo “chứng thư đã thay đổi”. Chức năng Kiểm tra nhanh cho phép kiểm tra một URL bất kỳ, còn Phân tích file đọc trực tiếp tệp chứng thư mà không cần kết nối.



Hình 24. Lịch sử quét và cảnh báo của một máy chủ



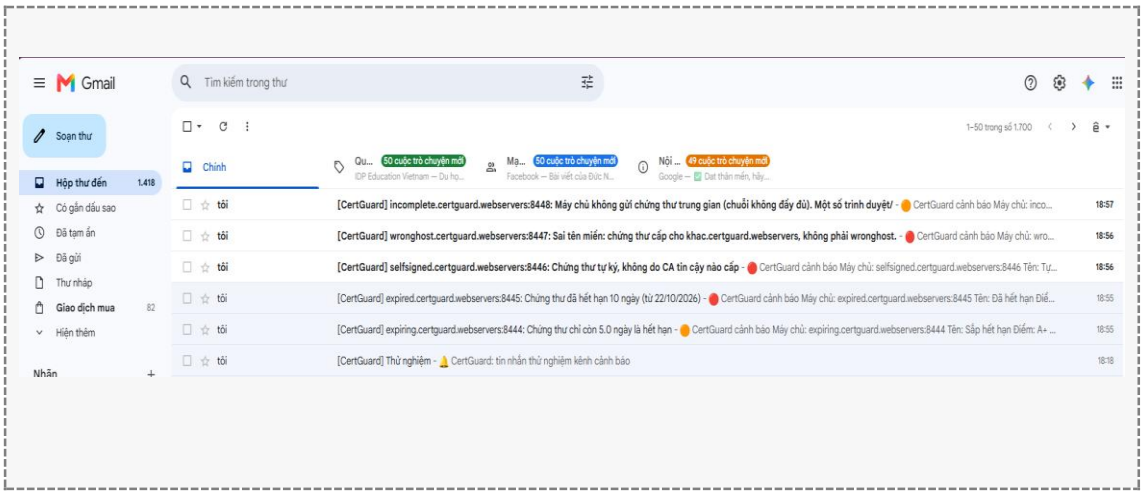
Hình 25. Kiểm tra nhanh một URL



Hình 26. Phân tích file chứng thư tải lên

4.5. Cảnh báo qua email

Khi thêm các máy chủ lỗi, CertGuard gửi email cảnh báo tới hộp thư quản trị viên qua Gmail SMTP. Mỗi email gồm tên máy chủ, điểm, số ngày còn lại, danh sách lỗi và thời điểm phát hiện. Mật khẩu ứng dụng Gmail được khai báo trong tệp `.env`, không lưu trong mã nguồn hay cơ sở dữ liệu; kết nối tới máy chủ Gmail được mã hóa bằng STARTTLS có xác thực chứng thư.



Hình 27. Các email cảnh báo nhận được trong Gmail

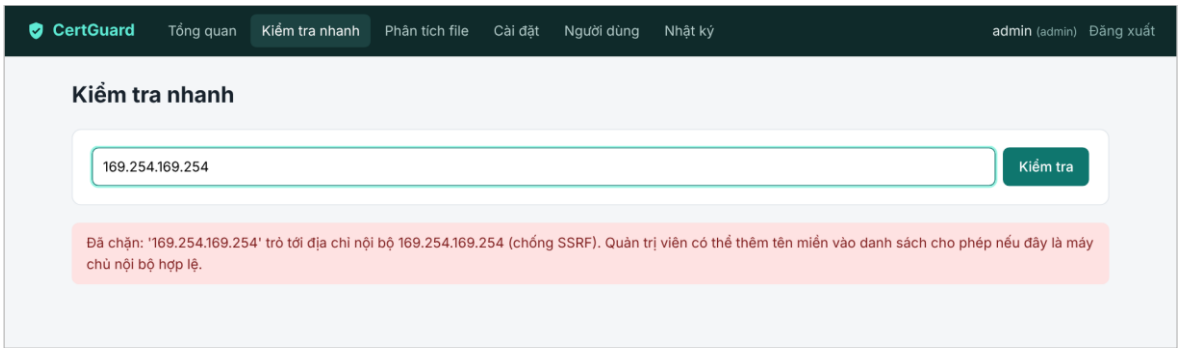


Hình 28. Nội dung email cảnh báo chứng thư hết hạn

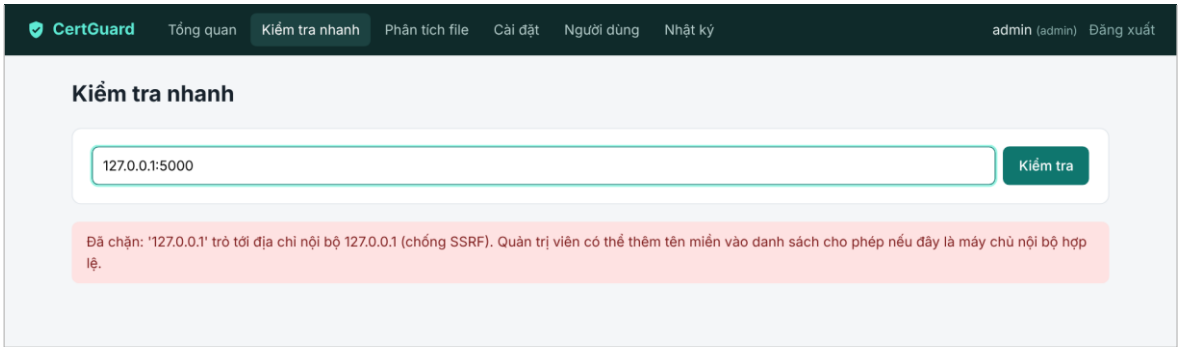
4.6. Kiểm thử bảo mật hệ thống

4.6.1. Chống SSRF

Nhập địa chỉ dịch vụ metadata của máy chủ cloud `169.254.169.254` và địa chỉ của chính hệ thống `127.0.0.1:5000` vào chức năng Kiểm tra nhanh: cả hai đều bị chặn và được ghi vào nhật ký với hành động `ssrf_blocked`. Các web server kiểm thử vẫn quét được vì tên miền `*.certguard.webservers` đã được quản trị viên đưa vào danh sách cho phép.



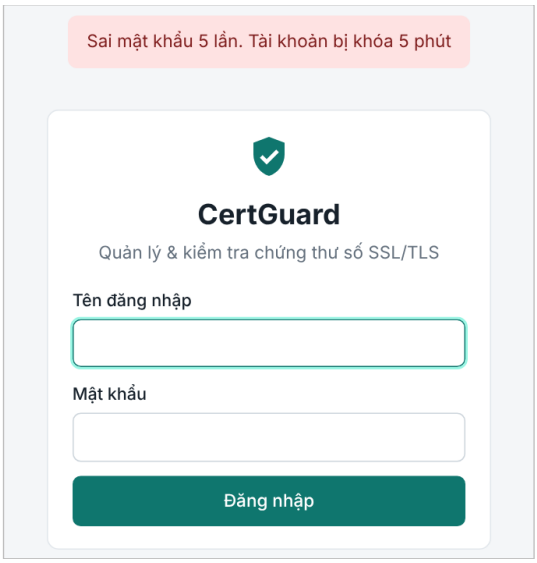
Hình 29. Chặn truy cập địa chỉ metadata 169.254.169.254



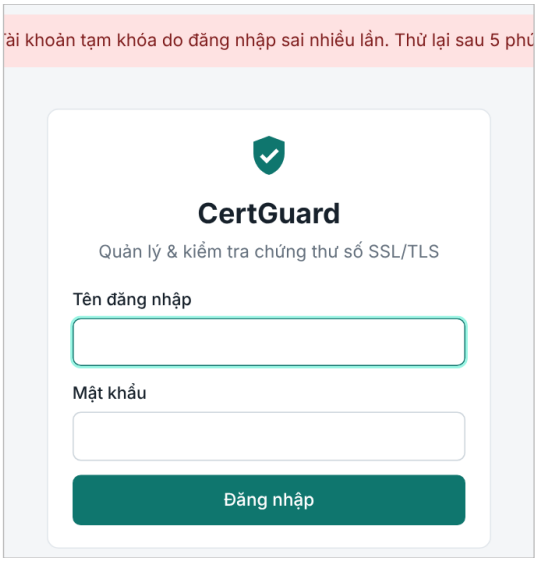
Hình 30. Chặn truy cập địa chỉ nội bộ 127.0.0.1

4.6.2. Chống dò mật khẩu

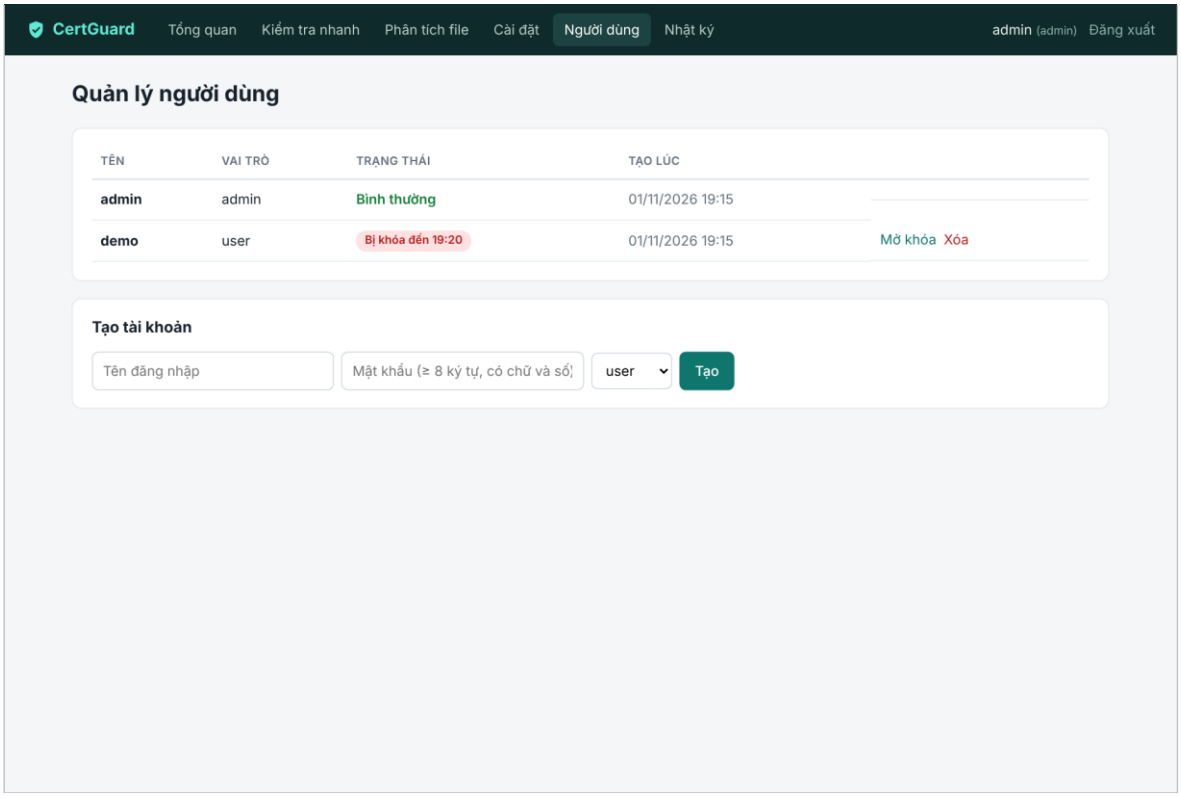
Đăng nhập tài khoản `demo` sai mật khẩu năm lần liên tiếp, tài khoản bị khóa năm phút; trong thời gian này, kể cả nhập đúng mật khẩu cũng không đăng nhập được. Quản trị viên có thể mở khóa sớm tại trang Người dùng.



Hình 31. Tài khoản bị khóa sau 5 lần nhập sai mật khẩu

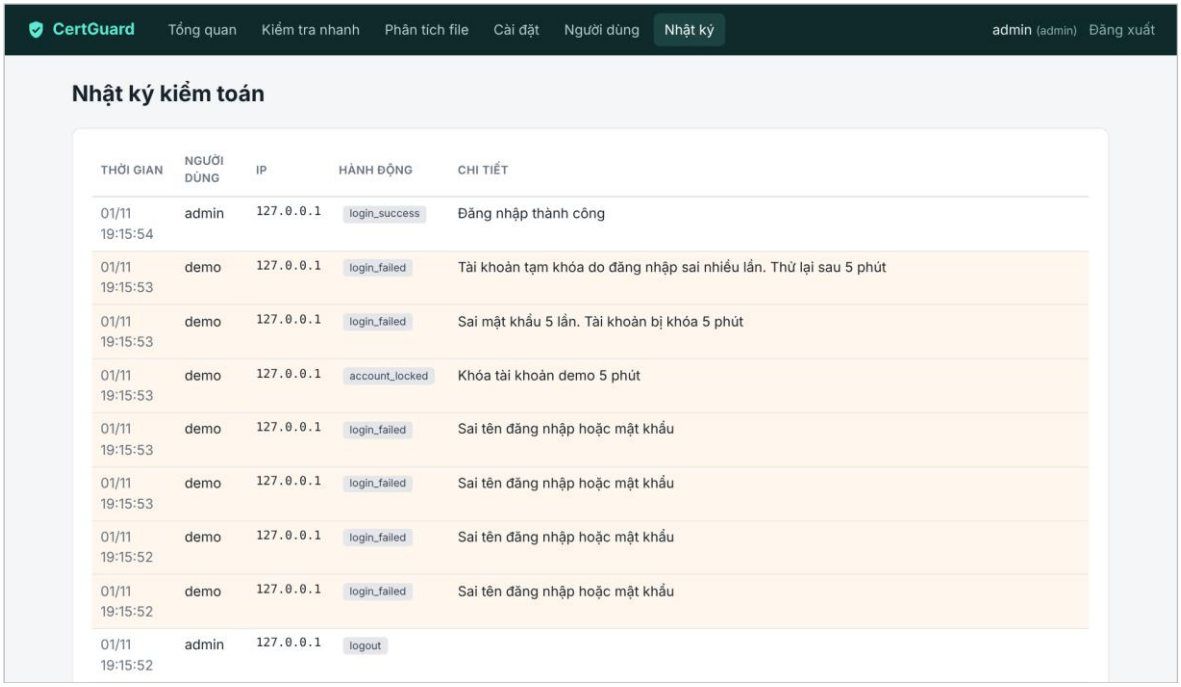


Hình 32. Nhập đúng mật khẩu trong thời gian bị khóa vẫn bị từ chối



Hình 33. Trang quản lý người dùng

4.6.3. Nhật ký kiểm toán và các kiểm thử khác



Hình 34. Nhật ký kiểm toán ghi lại các sự kiện bảo mật

Bảng 12. Kết quả kiểm thử bảo mật

Kiểm thử	Cách thực hiện	Kết quả
Truy cập khi chưa đăng nhập	Mở trực tiếp trang tổng quan	Chuyển hướng về trang đăng nhập
Gửi form không có CSRF token	Gửi POST /login thiếu trường _csrf	Bị từ chối, mã lỗi 400
Dò mật khẩu	Nhập sai 5 lần liên tiếp	Khóa tài khoản 5 phút, ghi account_locked
SSRF tới metadata cloud	Kiểm tra nhanh 169.254.169.254	Bị chặn, ghi ssrf_blocked
SSRF tới máy cục bộ	Kiểm tra nhanh 127.0.0.1:5000, localhost	Bị chặn
Đầu vào sai định dạng	Nhập javascript:alert(1), ftp://…, abc..com	Bị từ chối với thông báo phù hợp
Quyền user truy cập trang quản trị	Đăng nhập user, mở /settings	Bị từ chối, quay về tổng quan
Kiểm tra header bảo mật	Xem header phản hồi HTTP	Có Content-Security-Policy, X-Frame-Options, X-Content-Type-Options

4.7. Đối chứng kết quả và đánh giá

Để chứng minh kết quả không phải dữ liệu dựng sẵn, mỗi trang kết quả đều kèm lệnh OpenSSL tương ứng để kiểm tra độc lập. Kết quả của CertGuard được so sánh với OpenSSL và trình duyệt Chrome trên cùng các máy chủ.



Hình 35. Lệnh đối chứng OpenSSL được cung cấp trên trang kết quả

[CHÈN ẢNH CHỤP MÀN HÌNH]
Cửa sổ Git Bash chạy lệnh openssl s_client tới expired.certguard.webservers:8445, hiển thị dòng "Verify return code: 10 (certificate has expired)"
(Xóa khung này và dán ảnh vào đây)

Hình 36. Kết quả đối chứng bằng OpenSSL

Bảng 13. Đối chứng kết quả CertGuard với OpenSSL và Chrome

Máy chủ	OpenSSL (Verify return code)	Chrome	CertGuard
good	0 (ok)	Hợp lệ*	Hợp lệ, A+
expiring	0 (ok)	Hợp lệ*	Cảnh báo, còn 5 ngày
expired	10 (certificate has expired)	Báo lỗi hết hạn	Lỗi, F
selfsigned	18 (self-signed certificate)	Báo lỗi không tin cậy	Lỗi, F
wronghost	62 (hostname mismatch)	Báo lỗi sai tên	Lỗi, F
incomplete	21 (unable to verify the first certificate)	Báo lỗi không tin cậy	Cảnh báo, B
weak	0 (ok), khóa 1024 bit	Từ chối khóa yếu	Cảnh báo, C

(*) Khi Root CA nội bộ đã được cài vào kho tin cậy của máy.

Kết quả cho thấy CertGuard phát hiện đúng toàn bộ bảy tình huống, trùng khớp với hai công cụ độc lập. Đồng thời CertGuard cung cấp thông tin chi tiết hơn: chỉ rõ nguyên nhân, mức độ nghiêm trọng, điểm số, phát hiện các vấn đề cấu hình mà trình duyệt không hiển thị (TLS cũ, thiếu Forward Secrecy, thiếu HSTS), lưu lịch sử và tự động cảnh báo.

CHƯƠNG 5: KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

5.1. Kết quả đạt được

- Nắm vững và trình bày được cơ sở lý thuyết về mật mã khóa công khai, chữ ký số, chứng thư X.509, PKI, giao thức TLS, cơ chế thu hồi và các lỗi cấu hình thường gặp.
- Xây dựng hoàn chỉnh hệ thống CertGuard với các chức năng quản lý danh mục máy chủ, kiểm tra chứng thư và cấu hình TLS, chấm điểm, lưu lịch sử, phát hiện thay đổi, giám sát định kỳ và cảnh báo qua email.
- Lõi kiểm tra tự lập trình bằng Python, phân loại chính xác các lỗi: hết hạn, sắp hết hạn, tự ký, Root CA không tin cậy, thiếu chuỗi, sai tên miền, khóa yếu, thuật toán ký yếu, giao thức cũ, cipher yếu, thiếu Forward Secrecy, thiếu HSTS, bị thu hồi.
- Bản thân hệ thống được bảo vệ bằng nhiều lớp: chống SSRF và DNS rebinding, băm mật khẩu scrypt, khóa tài khoản, CSRF token, phân quyền, CSP, nhật ký kiểm toán, tách thông tin bí mật khỏi mã nguồn.
- Dựng được môi trường thực nghiệm gồm bảy web server Nginx thật; kết quả của hệ thống trùng khớp với OpenSSL và trình duyệt Chrome.

5.2. Hạn chế

- Hệ thống mới thực hiện kiểm tra và giám sát; việc cấp phát, gia hạn và thu hồi chứng thư vẫn do CA bên ngoài đảm nhận.
- Theo mô hình không dùng tác tử, CertGuard chỉ nhìn thấy máy chủ từ bên ngoài, không tự động cài chứng thư mới lên máy chủ được.
- Việc thăm dò bộ mã hóa phụ thuộc vào các thuật toán mà thư viện OpenSSL phía máy khách còn hỗ trợ.
- Cơ sở dữ liệu SQLite phù hợp quy mô vừa và nhỏ; khi giám sát hàng nghìn máy chủ cần chuyển sang hệ quản trị cơ sở dữ liệu lớn hơn.
- Chưa có xác thực hai yếu tố cho tài khoản quản trị.

5.3. Hướng phát triển

- Tích hợp **CA nội bộ** để cấp phát, gia hạn và thu hồi chứng thư ngay trong hệ thống, kèm phát hành CRL; khóa riêng của CA được mã hóa AES-GCM khi lưu trữ.
- Tích hợp giao thức **ACME** để tự động xin và gia hạn chứng thư Let's Encrypt.
- Bổ sung **tác tử** trên web server để tự động triển khai chứng thư mới và khởi động lại dịch vụ.
- Theo dõi nhật ký **Certificate Transparency** để phát hiện chứng thư lạ được cấp cho tên miền của tổ chức.
- Bổ sung xác thực hai yếu tố, thêm kênh cảnh báo (Telegram, Slack) và báo cáo tổng hợp định kỳ.

TÀI LIỆU THAM KHẢO

[1] D. Cooper và cộng sự, “RFC 5280 – Internet X.509 Public Key Infrastructure Certificate and CRL Profile”, IETF, 2008.

[2] E. Rescorla, “RFC 8446 – The Transport Layer Security (TLS) Protocol Version 1.3”, IETF, 2018.

[3] T. Dierks, E. Rescorla, “RFC 5246 – The Transport Layer Security (TLS) Protocol Version 1.2”, IETF, 2008.

[4] K. Moriarty, S. Farrell, “RFC 8996 – Deprecating TLS 1.0 and TLS 1.1”, IETF, 2021.

[5] S. Santesson và cộng sự, “RFC 6960 – X.509 Internet PKI Online Certificate Status Protocol – OCSP”, IETF, 2013.

[6] J. Hodges, C. Jackson, A. Barth, “RFC 6797 – HTTP Strict Transport Security (HSTS)”, IETF, 2012.

[7] CA/Browser Forum, “Baseline Requirements for the Issuance and Management of Publicly-Trusted TLS Server Certificates”, https://cabforum.org.

[8] Mozilla, “Server Side TLS – Recommended configurations”, https://wiki.mozilla.org/Security/Server_Side_TLS.

[9] NIST, “SP 800-52 Rev. 2 – Guidelines for the Selection, Configuration, and Use of TLS Implementations”, 2019.

[10] OWASP Foundation, “OWASP Top 10:2021” và “Server-Side Request Forgery Prevention Cheat Sheet”, https://owasp.org.

[11] Python Cryptographic Authority, “cryptography – X.509 and verification documentation”, https://cryptography.io.

[12] Pallets Projects, “Flask Documentation”, https://flask.palletsprojects.com.

[13] Python Software Foundation, “ssl — TLS/SSL wrapper for socket objects”, https://docs.python.org/3/library/ssl.html.